

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1	Introduction	With the prevalent use of technology in the provision of financial services, financial institutions must- (a) invest in the required expertise and risk controls to prevent operational disruptions given the complexity of Information Technology (IT) systems; (b) achieve the highest level of security to combat fast-changing digital crimes for public confidence; (c) maintain robust oversight to prevent transmission of risks with increased third party interlinkages; (d) build operational resilience against sophisticated and malicious cyber threats amidst heightened cyber risks globally; and (e) practice ethical and responsible use of technology for inclusive growth. This policy document sets out the Bank's policy objectives and minimum requirements to improve financial institutions' management of technology risk, including cyber risk. In applying this policy document, a financial institution shall have regard to the size and complexity of its operations, the level of technology use and its external stress exposure. Enforcement or supervisory actions can be taken against the financial institutions including its directors, officers and employees for any noncompliance with any provision marked as "S" in Part B of this policy document. Where the Bank considers that a financial institution's technology risk management has material weaknesses which, if not promptly and effectively addressed, might contribute to, or result in, non-compliance with this policy document, the Bank may, among others- (a) require an independent external review of the overall or specific areas of the financial institution's technology risk management; (b) require the financial institution to develop and implement specific remediation plan; (c) require the financial institution to hold additional capital; or (d) require the financial institution to take any other corrective action necessary to rectify the weaknesses in a sustainable manner.	Functional	No Relationship	N/A	N/A	N/A	0	
2	Applicability	Subject to paragraph 2.2, this policy document is applicable to all financial institutions as defined in paragraph 5.2.	Functional	No Relationship	N/A	N/A	N/A	0	
2(2)	Applicability	The following paragraphs and appendices are not applicable to certain financial institutions identified below:	Functional	No Relationship	N/A	N/A	N/A	0	
2(2)(a)	Applicability	Part C (paragraphs 16 to 17) and Appendices 6 and 7 are not applicable to- (i) operators of designated payment system; (ii) eligible e-money issuers; (iii) non-bank registered merchant acquirers; and (iv) intermediary remittance institutions; and	Functional	No Relationship	N/A	N/A	N/A	0	
2(2)(b)	Applicability	paragraphs 12.3 to 12.9 are not applicable to- (i) operators of designated payment system; and (ii) intermediary remittance institutions; and	Functional	No Relationship	N/A	N/A	N/A	0	
2(2)(c)	Applicability	paragraph 13.3 is not applicable to the following financial institutions, provided they have not been designated as National Critical Information Infrastructure (NCII) entities: (i) eligible e-money issuers; (ii) non-bank registered merchant acquirers; and (iii) intermediary remittance institutions.	Functional	No Relationship	N/A	N/A	N/A	0	
3	Legal Provisions	The requirements in this policy document are specified pursuant to- (a) sections 47(1), 47(2)(d) and 143(2) of the Financial Services Act 2013 (FSA); (b) sections 57(1), 57(2)(d) and 155(2) of the Islamic Financial Services Act 2013 (IFSA); (c) sections 41(1), 41(2)(b) and 116(1) of the Development Financial Institutions Act 2002 (DFIA); and (d) sections 34(2) and 74 of the Money Services Business Act 2011 (MSBA). The guidance in this policy document is issued pursuant to section 266 of the FSA, section 277 of the IFSA, section 126 of the DFIA and section 74 of the MSBA.	Functional	No Relationship	N/A	N/A	N/A	0	
4	Effective Date	This policy document comes into effect on 28 November 2025 except where otherwise stated explicitly in this policy document.	Functional	No Relationship	N/A	N/A	N/A	0	
5	Interpretation	The terms and expressions used in this policy document shall have the same meanings assigned to them in the FSA, IFSA, DFIA or MSBA, as the case may be, unless otherwise defined in this policy document.	Functional	No Relationship	N/A	N/A	N/A	0	
5(2)	Interpretation	For purposes of this policy document- "S" denotes a standard, an obligation, a requirement, specification, direction, condition and any interpretative, supplemental and transitional provisions that must be complied with. Non-compliance may result in enforcement action; "G" denotes guidance which may consist of statements or information intended to promote common understanding and advice or recommendations that are encouraged to be adopted; "affiliate" in relation to an entity, refers to any corporation that controls, is controlled by, or is under common control with, the entity; "board" refers to the board of directors of a financial institution, including any committee carrying out any of the responsibilities of the board under this policy document; "critical system" refers to any application system that supports the provision of critical banking, insurance, takaful, payment, investment or trading services, where failure of the system has the potential to significantly impair the financial institution's provision of financial services to customers or counterparties, business operations, financial position, reputation, or compliance with applicable laws and regulatory requirements; "customer and counterparty information" refers to any information relating to the affairs or the account, of any customer or counterparty of a financial institution in whatever form; "cyber incident" refers to a cyber event that adversely affects the cyber security of an information system or the information the system processes, stores or transmits whether resulting from malicious activity or not; "cyber resilience" refers to the ability of people, processes, IT systems, applications, platforms or infrastructures to withstand adverse cyber events; "digital services" refers to the provision of payment, remittance, banking, Islamic banking, insurance or takaful services delivered to customers via electronic channels and devices including Internet and mobile devices, self-service and point-of-sale terminals; "disruption" refers to an incident that causes degradation to the normal performance of a	Functional	No Relationship	N/A	N/A	N/A	0	
6	Related Legal Instruments and Policy Documents	This policy document must be read together with any relevant legal instruments, policy documents, guidelines, circulars, and supplementary documents issued by the Bank, including- (a) Guidelines on Data Management and MIS Framework issued on 23 October 2008; (b) Guidelines on Data Management and MIS Framework for Development Financial Institutions issued on 5 November 2012; (c) Policy Document on Risk Governance issued on 1 March 2013; (d) Policy Document on Introduction of New Products issued on 7 March 2014; (e) Policy Document on Compliance issued on 10 May 2016; (f) Policy Document on Operational Risk issued on 10 May 2016; (g) Policy Document on Debit Card and Debit Card-i issued on 2 December 2016; (h) Policy Document on Credit Card and Credit Card-i issued on 2 July 2019; (i) Policy Document on Outsourcing issued on 23 October 2019; (j) Policy Document on Interoperable Credit Transfer Framework issued on 23 December 2019; (k) Policy Document on Merchant Acquiring Services issued on 15 September 2021; (l) Circular of Notification on Consolidated List of Requirements Relating to Technology and Cyber Risk issued on 29 September 2022; (m) Policy Document on Business Continuity Management issued on 19 December 2022; (n) Policy Document on Responsibility Mapping issued on 29 December 2023; (o) Industry letter on Updated 2023 Financial Stability Board Cyber Lexicon issued on 28 February 2024; (p) Policy Document on Fair Treatment of Financial Consumers issued on 27 March 2024; (q) Specifications on Countermeasures to Combat E-Money Fraud issued on 8 April 2024; (r) Policy Document on Operational Risk Reporting issued on 10 April 2025; and (s) Management of Customer Information and Permitted Disclosures (MCIPD) issued on 31 October 2025.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7	Policy Documents and Circulars Superseded	This policy document supersedes the following policy documents, guidelines, circulars and notifications: (a) Guidelines on the Provision of Electronic Banking (e-banking) Services by Financial Institutions, including for the provisions under paragraphs 21, 22 and 26 issued on 18 November 2019; (b) Specifications on Measures to Combat Electronic Banking Fraud dated 23 August 2022; (c) Measures to Combat Fraud Monetised via Internet Banking and Mobile Banking dated 31 May 2022; (d) Policy Document on Risk Management in Technology (RMiT) issued on 1 June 2023; (e) Additional Guidance on Technology and Cyber Safeguards to Ensure the Protection of Customer Information issued on 10 July 2023; and (f) Specifications on Fraud Detection Standard dated 27 March 2024.	Functional	No Relationship	N/A	N/A	N/A	0	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Key Risk Indicators (KRIs)	GOV-05.2	Mechanisms exist to develop, report and monitor Key Risk Indicators (KRIs) to assist senior management in performance monitoring and trend analysis of the Security, Compliance & Resilience Program (SCRPP).	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Targeted Capability Maturity Levels	PRM-01.2	Mechanisms exist to define and identify targeted capability maturity levels.	3	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	3	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Risk Owner	RSK-03.2	Mechanisms exist to identify a risk owner for each item in the risk register to ensure clear accountability for unremediated risks.	5	
8.1	Responsibilities of the Board of Directors	The board must establish and approve the technology risk appetite which is aligned with the financial institution's risk appetite statement. In doing so, the board must- (a) approve the corresponding risk tolerances for technology-related events considering potential impact on business operations as well as its customers; (b) identify risk owner to ensure clear accountability and establish criteria and approving authority for the acceptance of residual risks by the institution; (c) ensure key risk indicators are identified to monitor existing and emerging risks against financial institution's risk tolerance; (d) ensure sufficiency and appropriate deployment of resources; and (e) conduct review of the technology risk appetite at regular intervals with sufficient deliberation to ensure such risk appetite remains relevant with changing risk environment.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRPP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT-related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Declaration of Conformity	CPL-01.5	Mechanisms exist to generate a declaration of conformity for each conformity assessment, where the document: (1) Is concise; (2) Unambiguously reflects the current status; (3) Is physically or electronically signed; and (4) Where possible, is machine readable.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT-related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT-related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT-related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	5	
8.2	Responsibilities of the Board of Directors	In discharging its oversight responsibility, the board must- (a) approve and review the adequacy of the financial institution's IT and cybersecurity strategic plans to meet business objectives covering a period of no less than three years; (b) endorse and oversee the effective implementation of a sound and robust technology risk management framework (TRMF) and cyber resilience framework (CRF), as required to be developed under paragraphs 9.1 and 11.2, for the continuity of operations and delivery of financial services; (c) require senior management to continuously demonstrate that risk assessments undertaken in relation to critical IT systems and use of emerging technology are robust and comprehensive, supported with adequate control measures and resources to mitigate IT and cyber risks arising from the execution of IT strategic plans; (d) ensure IT-related framework, policies and guidelines are reviewed at least once every three years (unless otherwise stated in this policy document) and apply a depth of review that is commensurate with the complexity of the financial institution's operations and changes in the risk environment; and (e) ensure risk management framework provide support to robust risk assessments in relation to technology related applications submitted to the Bank.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	5	
8.3	Responsibilities of the Board of Directors	The board must designate a board-level committee which shall be responsible for supporting the board in providing oversight over technology-related matters. The composition of the designated committee must include at least one member with technology experience and competencies.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	5	
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRCP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	5	
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	
8.4	Responsibilities of the Board of Directors	To promote effective discussion at the board level amidst a rapidly evolving technology and cyber risk landscape, the board must- (a) obtain regular updates on technology risk and cyber threats; (b) allocate sufficient time to discuss cyber risks, including the strategic, reputational and liquidity risks and impact of operational disruption to stakeholders which could arise from an extreme cyber incident. This shall be supported by input from external experts where appropriate; and (c) participate in relevant cybersecurity awareness and training programmes.	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	5	
8.5	Responsibilities of the Board of Directors	The board audit committee (BAC) shall be responsible for ensuring the effectiveness of the internal technology audit function. This shall include ensuring the adequate competence of the audit staff to perform technology audits. The BAC shall review and ensure appropriate audit scope, procedures and frequency of technology audits. The BAC shall also ensure effective oversight over the prompt closure of corrective actions to address technology control gaps.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	5	
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRCP).	5	
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Measures of Performance	GOV-05	Mechanisms exist to develop, report and monitor Security, Compliance & Resilience Program (SCRCP) measures of performance.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.6	Responsibilities of Senior Management	The senior management shall bear primary responsibility for the day-to-day management of technology risks including cyber risks. In fulfilling its responsibilities, senior management must- (a) implement board approved TRMF and CRF into specific policies and procedures that are consistent with the approved risk appetite and risk tolerance; (b) ensure that the crisis management plan for service disruptions provides for timely escalation of recovery action, taking into consideration the impact on customers, such as: (i) duration of disruption; (ii) number of customers affected by a disruption; and (iii) number and value of financial transaction impacted; and (c) provide regular updates to the board on the status of key performance indicators with pertinent information on the risk controls to facilitate informed performance review.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	5	
8.7	Responsibilities of Senior Management	The senior management must establish a cross-functional committee to provide guidance on the financial institution's technology plans and operations. The members of the committee must include senior management from both cyber and technology functions, as well as major business units. The committee's responsibilities shall include the following: (a) oversee the formulation and effective implementation of the strategic technology plan and associated technology policies and procedures; (b) provide timely updates to the board on key technology matters; and (c) approve any deviation from technology-related policies after having carefully considered a robust assessment of related risks. Material deviations shall be reported to the board.	Functional	Subset Of	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	10	
9.1	Risk Management Framework	A financial institution must ensure that the TRMF is an integral part of the financial institution's enterprise risk management framework (ERM).	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk-Based Security Categorization	RSK-02	Mechanisms exist to categorize Technology Assets, Applications, Services and/or Data (TAASD) in accordance with applicable laws, regulations and contractual obligations that: (1) Document the security categorization results (including supporting rationale) in the security plan for systems; and (2) Ensure the security categorization decision is reviewed and approved by the asset owner.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Impact-Level Prioritization	RSK-02.1	Mechanisms exist to prioritize the impact level for Technology Assets, Applications and/or Services (TAAS) to prevent potential disruptions.	3	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Catalog	RSK-03.1	Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or resilience-related: (1) Assessments; (2) Audits; and/or (3) Incidents.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Threat Modeling	TDA-06.2	Mechanisms exist to perform threat modelling and other secure design techniques, to ensure that threats to software and solutions are identified and accounted for.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their importance in supporting the delivery of high-value services.	5	
9.2	Risk Management Framework	The TRMF must include the following: (a) clear definition of technology risk; (b) clear responsibilities assigned for the management of technology risk at different levels and across functions, with appropriate governance and reporting arrangements; (c) the identification of technology risks to which the financial institution is exposed, including risks from the adoption of new or emerging technology; (d) risk classification of all information assets / systems based on its criticality; (e) risk measurement and assessment approaches and methodologies; (f) risk controls and mitigations; (g) continuous monitoring to timely detect and address any material risks; (h) effective information system to ensure the technology risk profile remains accurate and up to date; (i) identification of key resources and interdependencies (including critical third party service providers and their connected parties) which support delivery of critical technology functions; (j) undertake scenario analysis to strengthen capacity and readiness to resume critical systems under severe conditions; and (k) effective incident management policies and procedures to minimise the impact of any service disruption on the financial institution and its customers, by restoring the affected service or system to a secure and stable state as quickly as possible.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	
9.3	Risk Management Framework	A financial institution must establish an independent enterprise-wide technology risk management function which is responsible for- (a) implementing the TRMF and CRF; (b) advising on critical technology projects and ensuring critical issues that may have an impact on the financial institution's risk tolerance are adequately deliberated or escalated in a timely manner; and (c) providing independent views to the board and senior management on third party assessments, where necessary.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	5	
9.3	Risk Management Framework	A financial institution must establish an independent enterprise-wide technology risk management function which is responsible for- (a) implementing the TRMF and CRF; (b) advising on critical technology projects and ensuring critical issues that may have an impact on the financial institution's risk tolerance are adequately deliberated or escalated in a timely manner; and (c) providing independent views to the board and senior management on third party assessments, where necessary.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
9.3	Risk Management Framework	A financial institution must establish an independent enterprise-wide technology risk management function which is responsible for- (a) implementing the TRMF and CRF; (b) advising on critical technology projects and ensuring critical issues that may have an impact on the financial institution's risk tolerance are adequately deliberated or escalated in a timely manner; and (c) providing independent views to the board and senior management on third party assessments, where necessary.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	
9.3	Risk Management Framework	A financial institution must establish an independent enterprise-wide technology risk management function which is responsible for- (a) implementing the TRMF and CRF; (b) advising on critical technology projects and ensuring critical issues that may have an impact on the financial institution's risk tolerance are adequately deliberated or escalated in a timely manner; and (c) providing independent views to the board and senior management on third party assessments, where necessary.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	8	
9.4	Designated Chief Information Security Officer	A financial institution must designate a Chief Information Security Officer (CISO) by whatever name called, to be responsible for the technology risk management function of the financial institution. The financial institution must ensure that the CISO has sufficient authority, independence and resources. The CISO shall- (a) be independent from day-to-day technology operations; (b) apprise board and senior management of current and emerging technology risks which could potentially affect the financial institution's risk profile; (c) have the requisite technical skills in emerging	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRCP).	8	
9.4	Designated Chief Information Security Officer	A financial institution must designate a Chief Information Security Officer (CISO) by whatever name called, to be responsible for the technology risk management function of the financial institution. The financial institution must ensure that the CISO has sufficient authority, independence and resources. The CISO shall- (a) be independent from day-to-day technology operations; (b) apprise board and senior management of current and emerging technology risks which could potentially affect the financial institution's risk profile; (c) have the requisite technical skills in emerging	Functional	Intersects With	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
9.5	Designated Chief Information Security Officer	The CISO shall be responsible for ensuring that the financial institution's information assets and technologies are adequately protected, which includes- (a) formulating appropriate policies for the effective implementation of TRMF and CRF; (b) enforcing compliance with these policies, frameworks and other technology-related regulatory requirements; and (c) advising senior management on technology risk and security matters, including developments in the financial institution's technology security risk profile in relation to its business and operations.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	5	
9.5	Designated Chief Information Security Officer	The CISO shall be responsible for ensuring that the financial institution's information assets and technologies are adequately protected, which includes- (a) formulating appropriate policies for the effective implementation of TRMF and CRF; (b) enforcing compliance with these policies, frameworks and other technology-related regulatory requirements; and (c) advising senior management on technology risk and security matters, including developments in the financial institution's technology security risk profile in relation to its business and operations.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
9.5	Designated Chief Information Security Officer	The CISO shall be responsible for ensuring that the financial institution's information assets and technologies are adequately protected, which includes- (a) formulating appropriate policies for the effective implementation of TRMF and CRF; (b) enforcing compliance with these policies, frameworks and other technology-related regulatory requirements; and (c) advising senior management on technology risk and security matters, including developments in the financial institution's technology security risk profile in relation to its business and operations.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRCP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
9.5	Designated Chief Information Security Officer	The CISO shall be responsible for ensuring that the financial institution's information assets and technologies are adequately protected, which includes- (a) formulating appropriate policies for the effective implementation of TRMF and CRF; (b) enforcing compliance with these policies, frameworks and other technology-related regulatory requirements; and (c) advising senior management on technology risk and security matters, including developments in the financial institution's technology security risk profile in relation to its business and operations.	Functional	Intersects With	Business As Usual (BAU) Security, Compliance & Resilience Practices	GOV-14	Mechanisms exist to incorporate security, compliance and resilience principles into Business As Usual (BAU) practices through executive leadership involvement.	5	
9.5	Designated Chief Information Security Officer	The CISO shall be responsible for ensuring that the financial institution's information assets and technologies are adequately protected, which includes- (a) formulating appropriate policies for the effective implementation of TRMF and CRF; (b) enforcing compliance with these policies, frameworks and other technology-related regulatory requirements; and (c) advising senior management on technology risk and security matters, including developments in the financial institution's technology security risk profile in relation to its business and operations.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	
10.1	Technology Project Management	A financial institution must establish appropriate governance requirements commensurate with the risk and complexity of technology projects undertaken. This shall include project oversight roles and responsibilities, authority and reporting structures, and risk assessments throughout the project life cycle.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology	Functional	Intersects With	Material Risks	GOV-16.1	Mechanisms exist to define criteria necessary to designate a risk as a material risk.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Defensible Evidence of Due Diligence	CPL-13.1	Mechanisms exist to produce evidence of due diligence activities performed, capable of withstanding external audit or regulatory scrutiny.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
10.2	Technology Project Management	The risk assessments shall identify and address the key risks arising from the implementation of technology projects. These include the risks that could threaten successful project implementation and the risks that a project failure will lead to a broader impact on the financial institution's operational capabilities. At a minimum, due regard shall be given to the following areas: (a) the adequacy and competency of resources including those of the vendor to effectively implement the project; (b) the complexity of systems to be implemented such as the use of unproven or unfamiliar technology and the corresponding risks of integrating the new technology into existing systems, managing multiple vendor-proprietary technologies, large-scale data migration or cleansing efforts and extensive system customisation; (c) the adequacy and configuration of security controls throughout the project life cycle to mitigate cybersecurity breaches or exposure of confidential data; (d) the comprehensiveness of the user requirement specifications to mitigate risks from extensive changes in project scope or deficiencies in meeting business needs; (e) the robustness of system and user testing strategies to reduce risks of undiscovered system faults and functionality errors; (f) the appropriateness of system deployment and fallback strategies to mitigate risks from prolonged system stability issues; and (g) the adequacy of disaster recovery operational readiness following the implementation of new or enhanced systems.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
10.3	Technology Project Management	The board and senior management must receive and review timely reports on the management of these risks on an ongoing basis throughout the implementation of significant projects.	Functional	Subset Of	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	10	
10.4	System Development and Acquisition	A financial institution must establish a framework to guide the design, planning, implementation, and governance of an enterprise technology architecture. Thus, the financial institution must ensure the framework carry out these functions- (a) provides a comprehensive view of technology throughout the financial institution, baseline architecture components and key rationale for their use; (b) is an overall technical design and high-level plan that describes the financial institution's technology infrastructure, systems' interconnectivity and dependencies (e.g. fallback facility), and security controls; (c) contains mapping to supported business functions, organisation units, applications, and data to enable business impact analysis; (d) defines principles and guideline to govern the design and maintenance of the network infrastructure, related technology controls, and IT security policies; and (e) outline longer-term priorities to guide its evolution.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	
10.4	System Development and Acquisition	A financial institution must establish a framework to guide the design, planning, implementation, and governance of an enterprise technology architecture. Thus, the financial institution must ensure the framework carry out these functions- (a) provides a comprehensive view of technology throughout the financial institution, baseline architecture components and	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF); (2) Sherwood Applied Business Security Architecture (SABSA); and/or	5	
10.4	System Development and Acquisition	A financial institution must establish a framework to guide the design, planning, implementation, and governance of an enterprise technology architecture. Thus, the financial institution must ensure the framework carry out these functions- (a) provides a comprehensive view of technology throughout the financial institution, baseline architecture components and key rationale for their use; (b) is an overall technical design and high-level plan that describes the financial institution's technology infrastructure, systems' interconnectivity and dependencies (e.g. fallback facility), and security controls; (c) contains mapping to supported business functions, organisation units, applications, and data to enable business impact analysis; (d) defines principles and guideline to govern the design and maintenance of the network infrastructure, related technology controls, and IT security policies; and (e) outline longer-term priorities to guide its evolution.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.5	System Development and Acquisition	A financial institution must adopt a methodology for an effective and secure implementation of IT systems. Key phases of System Development Life Cycle (SDLC) shall include requirement, design, development, testing, deployment, change management, maintenance and decommissioning, and integrate with- (a) enterprise architecture to ensure successful execution of business strategy; (b) risk management policies and practices to achieve business objectives; and (c) security principles and requirements to ensure confidentiality, integrity, and availability of customer and counterparty information.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
10.5	System Development and Acquisition	A financial institution must adopt a methodology for an effective and secure implementation of IT systems. Key phases of System Development Life Cycle (SDLC) shall include requirement, design, development, testing, deployment, change management, maintenance and decommissioning, and integrate with- (a) enterprise architecture to ensure successful execution of business strategy; (b) risk management policies and practices to achieve business objectives; and (c) security principles and requirements to ensure confidentiality, integrity, and availability of customer and counterparty information.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	
10.5	System Development and Acquisition	A financial institution must adopt a methodology for an effective and secure implementation of IT systems. Key phases of System Development Life Cycle (SDLC) shall include requirement, design, development, testing, deployment, change management, maintenance and decommissioning, and integrate with- (a) enterprise architecture to ensure successful execution of business strategy; (b) risk management policies and practices to achieve business objectives; and (c) security principles and requirements to ensure confidentiality, integrity, and availability of customer and counterparty information.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	
10.5	System Development and Acquisition	A financial institution must adopt a methodology for an effective and secure implementation of IT systems. Key phases of System Development Life Cycle (SDLC) shall include requirement, design, development, testing, deployment, change management, maintenance and decommissioning, and integrate with- (a) enterprise architecture to ensure successful execution of business strategy; (b) risk management policies and practices to achieve business objectives; and (c) security principles and requirements to ensure confidentiality, integrity, and availability of customer and counterparty information.	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF); (2) Sherwood Applied Business Security Architecture (SABSA); and/or (3) An organization-defined reference architecture.	5	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.);	5	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Intersects With	Threat Analysis & Flaw Remediation During Development	IAO-04	Mechanisms exist to require system developers and integrators to create and execute a Security Testing and Evaluation (ST&E) plan, or similar process, to identify and remediate flaws during development.	5	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Intersects With	Technical Verification	IAO-06	Mechanisms exist to perform Information Assurance Program (IAP) activities to evaluate the design, implementation and effectiveness of technical security, compliance and resilience controls.	5	
10.6	System Development and Acquisition	A financial institution must meet enterprise security, governance and compliance requirements when using rapid system development methodology. Given the dynamic environment can increase likelihood of errors, a financial institution shall automate the IT security compliance review to prevent unauthorised access as well as the discovery and testing of security vulnerabilities to ensure secure release of new IT services.	Functional	Intersects With	Security Authorization	IAO-07	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are officially authorized prior to "go live" in a production environment.	5	
10.7	System Development and Acquisition	A financial institution shall physically segregate the production environment from the development and testing environment to mitigate the risk of unauthorised changes to the production systems. Where a financial institution is relying on a cloud environment, the financial institution shall ensure that these environments are not running on the same virtual host.	Functional	Intersects With	Secure Development Environments	TDA-07	Mechanisms exist to maintain a segmented development network to ensure a secure development environment.	5	
10.7	System Development and Acquisition	A financial institution shall physically segregate the production environment from the development and testing environment to mitigate the risk of unauthorised changes to the production systems. Where a financial institution is relying on a cloud environment, the financial institution shall ensure that these environments are not running on the same virtual host.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	8	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Assessment Boundaries	IAO-01.1	Mechanisms exist to establish the scope of assessments by defining the assessment boundary, according to people, processes and technology that directly or indirectly impact the confidentiality, integrity, availability and safety of the Technology Assets, Applications, Services and/or Data (TAASD) under review.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Assessor Independence	IAO-02.1	Mechanisms exist to ensure assessors or assessment teams have the appropriate independence to conduct security, compliance and/or resilience control assessments.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Security Assessment Report (SAR)	IAO-02.4	Mechanisms exist to produce a Security Assessment Report (SAR) at the conclusion of a security assessment to certify the results of the assessment and assist with any remediation actions.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Threat Analysis & Flaw Remediation During Development	IAO-04	Mechanisms exist to require system developers and integrators to create and execute a Security Testing and Evaluation (ST&E) plan, or similar process, to identify and remediate flaws during development.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies);	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Technical Verification	IAO-06	Mechanisms exist to perform Information Assurance Program (IAP) activities to evaluate the design, implementation and effectiveness of technical security, compliance and resilience controls.	5	
10.8	System Development and Acquisition	A financial institution must establish a sound methodology for a rigorous system testing prior to deployment. The testing shall ensure that the system meets user requirements and performs robustly. Where sensitive test data is used, the financial institution must ensure proper authorisation procedures and adequate measures to prevent their unauthorised disclosure are in place.	Functional	Intersects With	Security Authorization	IAO-07	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are officially authorized prior to "go live" in a production environment.	5	
10.9	System Development and Acquisition	The scope of system testing referred to in paragraph 10.8 may include unit testing, integration testing, user acceptance testing, application security testing, stress and load testing, regression, exception and negative testing, where applicable.	Functional	Intersects With	Assessment Boundaries	IAO-01.1	Mechanisms exist to establish the scope of assessments by defining the assessment boundary, according to people, processes and technology that directly or indirectly impact the confidentiality, integrity, availability and safety of the Technology Assets, Applications, Services and/or Data (TAASD) under review.	5	
10.9	System Development and Acquisition	The scope of system testing referred to in paragraph 10.8 may include unit testing, integration testing, user acceptance testing, application security testing, stress and load testing, regression, exception and negative testing, where applicable.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
10.9	System Development and Acquisition	The scope of system testing referred to in paragraph 10.8 may include unit testing, integration testing, user acceptance testing, application security testing, stress and load testing, regression, exception and negative testing, where applicable.	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases;	5	
10.10	System Development and Acquisition	A financial institution must ensure any changes to the source code of critical systems are subject to adequate source code reviews to ensure code is secure and developed in line with recognised coding practices prior to introducing any system changes.	Functional	Intersects With	Threat Analysis & Flaw Remediation During Development	IAO-04	Mechanisms exist to require system developers and integrators to create and execute a Security Testing and Evaluation (ST&E) plan, or similar process, to identify and remediate flaws during development.	8	
10.10	System Development and Acquisition	A financial institution must ensure any changes to the source code of critical systems are subject to adequate source code reviews to ensure code is secure and developed in line with recognised coding practices prior to introducing any system changes.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	8	
10.11	System Development and Acquisition	A financial institution must establish appropriate procedures to independently review and approve system changes. The financial institution must also establish and test contingency plans in the event of an unsuccessful implementation of material changes to minimise any business disruption.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	
10.11	System Development and Acquisition	A financial institution must establish appropriate procedures to independently review and approve system changes. The financial institution must also establish and test contingency plans in the event of an unsuccessful implementation of material changes to minimise any business disruption.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	
10.11	System Development and Acquisition	A financial institution must establish appropriate procedures to independently review and approve system changes. The financial institution must also establish and test contingency plans in the event of an unsuccessful implementation of material changes to minimise any business disruption.	Functional	Intersects With	Security, Compliance & Resilience Representative for Asset Lifecycle Changes	CHG-02.3	Mechanisms exist to include a cybersecurity and/or data protection representative in the configuration change control review process.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.11	System Development and Acquisition	A financial institution must establish appropriate procedures to independently review and approve system changes. The financial institution must also establish and test contingency plans in the event of an unsuccessful implementation of material changes to minimise any business disruption.	Functional	Intersects With	Security Impact Analysis for Changes	CHG-03	Mechanisms exist to analyze proposed changes for potential security impacts, prior to the implementation of the change.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Library Privileges	CHG-04.5	Mechanisms exist to restrict software library privileges to those individuals with a pertinent business need for access.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Pre-Established Secure Configurations	TDA-02.4	Mechanisms exist to ensure vendors / manufacturers: (1) Deliver the Technology Asset, Application and/or Service (TAAS) with a pre-established, secure configuration implemented; and (2) Use the pre-established, secure configuration as the default for any subsequent TAAS reinstallation or upgrade.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Security, Compliance & Resilience Representatives For Product Changes	TDA-02.7	Mechanisms exist to include appropriate security, compliance and resilience representatives in the product feature and/or functionality change control review process.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Archiving Software Releases	TDA-20.2	Mechanisms exist to archive software releases and all of their components (e.g., code, package files, third-party libraries, documentation) to maintain integrity verification information.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Software Escrow	TDA-20.3	Mechanisms exist to escrow source code and supporting documentation to ensure software availability in the event the software provider goes out of business or is unable to provide support.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Product Conformity Governance	TDA-21	Mechanisms exist to ensure developed Technology Assets, Applications and/or Services (TAAS) conform to applicable statutory and regulatory requirements, based on the product's and/or service's: (1) Use case(s); and (2) Geographic markets.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.12	System Development and Acquisition	In relation to critical systems that are developed or maintained by third party service provider, a financial institution must, through contractual obligations, require third party service provider to: (a) provide sufficient notice to the financial institution before any changes are undertaken that may impact the IT system; (b) demonstrate that it adopts secure by design principles in IT system development methodology to mitigate cyber risks from propagating across the supply chain; and (c) ensure the source code continues to be readily accessible for business continuity.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
10.13	System Development and Acquisition	When decommissioning critical systems, a financial institution must ensure minimal adverse impact on customers and business operations. This includes establishing and testing contingency plans in the event of unsuccessful system decommissioning.	Functional	Subset Of	Decommissioning	AST-30	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are properly decommissioned so that data is properly transitioned to new systems or archived in accordance with applicable organizational standards, as well as statutory, regulatory and contractual obligations.	10	
10.14	System Development and Acquisition	A financial institution may deploy automated tools for software development, testing, software deployment, change management, code scanning and software version control to facilitate timely security assessment of critical systems in keeping with growing complexity in IT systems and emerging cyber threats.	Functional	Subset Of	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	10	
10.14	System Development and Acquisition	A financial institution may deploy automated tools for software development, testing, software deployment, change management, code scanning and software version control to facilitate timely security assessment of critical systems in keeping with growing complexity in IT systems and emerging cyber threats.	Functional	Intersects With	Dynamic Code Analysis	TDA-09.3	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to employ dynamic code analysis tools to identify and remediate common flaws and document the results of the analysis.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security	Functional	Intersects With	Open Source Software	CFG-04.1	Mechanisms exist to establish parameters for the secure use of open source software.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security	Functional	Intersects With	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.); (7) Vulnerability management; (8) Malicious code; (9) Insider threats; (10) Performance/load testing; (11) Artificial Intelligence and Autonomous Technologies (AAT); and/or (12) Other Technology Assets, Applications and/or Services (TAAS) that	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Security Authorization	IAO-07	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are officially authorized prior to "go live" in a production environment.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Supply Chain Risk Management (SCRM) Plan	RSK-09	Mechanisms exist to develop a plan for Supply Chain Risk Management (SCRM) associated with the development, acquisition, maintenance and disposal of Technology Assets, Applications and/or Services (TAAS), including documenting selected mitigating actions and monitoring performance against those plans.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Supply Chain Risk Assessment	RSK-09.1	Mechanisms exist to periodically assess supply chain risks associated with Technology Assets, Applications and/or Services (TAAS).	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Software Bill of Materials (SBOM)	TDA-04.2	Mechanisms exist to generate, or obtain, a Software Bill of Materials (SBOM) for Technology Assets, Applications and/or Services (TAAS) that lists software packages in use, including versions and applicable licenses.	5	
10.15	System Development and Acquisition	Where a third party software is used, a financial institution should consider the potential risks and impacts a cyber supply chain incident may pose to its overall business operations and services. A financial institution may consider: (a) adopting Software-Bill-of-Materials (SBOM) to automate the identification and continuous monitoring of potential security vulnerabilities including security issues associated with third party software components; and (b) establishing open-source software security policy and procedures. This includes ensuring secure access to source code repositories in third party platforms, regular monitoring to prevent data leakages, adoption of secure coding practices, robust testing of open-source software and timely vulnerability assessment to mitigate security vulnerabilities and propagation of malwares across supply chain.	Functional	Intersects With	Supply Chain Risk Management (SCRM)	TPM-03	Mechanisms exist to: (1) Evaluate security risks and threats associated with Technology Assets, Applications and/or Services (TAAS) supply chains; and (2) Take appropriate remediation actions to minimize the organization's exposure to those risks and threats, as necessary.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.16	System Development and Acquisition	A financial institution must develop and implement robust policies to identify and reduce shadow IT risks.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
10.16	System Development and Acquisition	A financial institution must develop and implement robust policies to identify and reduce shadow IT risks.	Functional	Intersects With	Shadow Information Technology Detection	OPS-07	Mechanisms exist to detect the presence of unauthorized Technology Assets, Applications and/or Services (TAAS) in use.	5	
10.17	Patch and End-of-Life System Management	A financial institution must ensure that all systems including digital services are not running with known security vulnerabilities, on outdated platform or end-of-life (EOL) technology systems. In this regard, a financial institution must: (a) maintain current security baseline for the security	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	
10.17	Patch and End-of-Life System Management	A financial institution must ensure that all systems including digital services are not running with known security vulnerabilities, on outdated	Functional	Intersects With	Unsupported Technology Assets, Applications	TDA-17	Mechanisms exist to prevent unsupported Technology Assets, Applications and/or Services (TAAS) by:	8	
10.17	Patch and End-of-Life System Management	A financial institution must ensure that all systems including digital services are not running with known security vulnerabilities, on outdated platform or end-of-life (EOL) technology systems. In this regard, a financial institution must: (a) maintain current security baseline for the security hardening of technology components and ensure the security baseline is accurate and up to date; (b) continuously monitor and implement latest patch releases in a timely manner; (c) identify, plan and implement remedial action for technology systems that are approaching EOL; and (d) obtain management approval for any exception permitting the continued use of unsupported or outdated technology. This exception must be substantiated by a thorough risk assessment with clear timeline for phasing out the outdated technology and are regularly reviewed at least on annual basis to ensure associated risks are effectively managed.	Functional	Intersects With	Vulnerability & Patch Management Program (VPMP)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	8	
10.17	Patch and End-of-Life System Management	A financial institution must ensure that all systems including digital services are not running with known security vulnerabilities, on outdated platform or end-of-life (EOL) technology systems. In this regard, a financial institution must: (a) maintain current security baseline for the security hardening of technology components and ensure the security baseline is accurate and up to date; (b) continuously monitor and implement latest patch releases in a timely manner; (c) identify, plan and implement remedial action for technology systems that are approaching EOL; and (d) obtain management approval for any exception permitting the continued use of unsupported or outdated technology. This exception must be substantiated by a thorough risk assessment with clear timeline for phasing out the outdated technology and are regularly reviewed at least on annual basis to ensure associated risks are effectively managed.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Stakeholder Notification of Changes	CHG-05	Mechanisms exist to ensure stakeholders are made aware of and understand the impact of proposed changes.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Vulnerability & Patch Management Program (VPMP)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Malaysia - Risk Management in Technology (RMiT) (2025)**

Focal Document URL: <https://www.bnm.gov.my/-/pd-mit-nov25>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-apac-mys-bnm-mit-2025.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Vulnerability Ranking	VPM-03	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Continuous Vulnerability Remediation Activities	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	
10.18	Patch and End-of-Life System Management	A financial institution must establish a patch and EOL management framework which addresses among others the following requirements: (a) identification and risk assessment of all technology assets for potential vulnerabilities arising from undeployed patches or EOL systems; (b) formulation of criteria, priority and turnaround time for patch deployment according to the severity of the vulnerabilities identified; (c) conduct of compatibility testing prior to the deployment of patches to minimise disruption to connected systems; (d) adherence to the workflow for end-to-end patch deployment processes including approval, testing, monitoring and tracking of activities; and (e) end-user awareness for orderly transition.	Functional	Intersects With	Pre-Deployment Patch Testing	VPM-05.6	Mechanisms exist to perform due diligence on software and/or firmware update stability by conducting pre-production testing in a non-production environment.	5	
10.19	Patch and End-of-Life System Management	A financial institution must continually monitor the effectiveness and security of the technology in use, incorporating developments in technology that may disrupt existing security controls. A financial institution shall: (a) ensure its board receives advice on the potential impact to business operation arising from evolving technology landscape; (b) formulate long-term strategy to address anticipated changes with allocation of competent resources to manage associated risks, including new cyber adversary tactics and techniques; and (c) establish roadmap for system migration to preserve security and reliability of the technology infrastructure in an orderly manner.	Functional	Subset Of	Vulnerability & Patch Management Program (VPMP)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	
10.19	Patch and End-of-Life System Management	A financial institution must continually monitor the effectiveness and security of the technology in use, incorporating developments in technology that may disrupt existing security controls. A financial institution shall: (a) ensure its board receives advice on the potential impact to business operation arising from evolving technology landscape; (b) formulate long-term strategy to address anticipated changes with allocation of competent resources to manage associated risks, including new cyber adversary tactics and techniques; and (c) establish roadmap for system migration to preserve security and reliability of the technology infrastructure in an orderly manner.	Functional	Intersects With	Centralized Management of Flaw Remediation Processes	VPM-05.1	Mechanisms exist to centrally-manage the flaw remediation process.	8	
10.20	Cryptography	A financial institution must establish a robust and resilient cryptography policy to promote the adoption of strong cryptographic controls for protection of important data and information. This policy, at a minimum, shall address requirements for: (a) the adoption of industry standards for encryption algorithms, message authentication, hash functions, digital signatures and random number generation; (b) the adoption of robust and secure processes in managing cryptographic key lifecycles which include generation, distribution, renewal, usage, storage, recovery, revocation and destruction; (c) the periodic review, at least annually, of all cryptographic standards and algorithms currently in use for critical systems, external	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
10.20	Cryptography	A financial institution must establish a robust and resilient cryptography policy to promote the adoption of strong cryptographic controls for protection of important data and information. This policy, at a minimum, shall address requirements for: (a) the adoption of industry standards for encryption algorithms, message authentication, hash functions, digital signatures and random number generation; (b) the adoption of robust and secure processes in managing cryptographic key lifecycles which include generation, distribution, renewal, usage, storage, recovery, revocation and destruction; (c) the periodic review, at least annually, of all cryptographic standards and algorithms currently in use for critical systems, external	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	8	
10.20	Cryptography	A financial institution must establish a robust and resilient cryptography policy to promote the adoption of strong cryptographic controls for protection of important data and information. This policy, at a minimum, shall address requirements for: (a) the adoption of industry standards for encryption algorithms, message authentication, hash functions, digital signatures and random number generation; (b) the adoption of robust and secure processes in managing cryptographic key lifecycles which include generation, distribution, renewal, usage, storage, recovery, revocation and destruction; (c) the periodic review, at least annually, of all cryptographic standards and algorithms currently in use for critical systems, external linked or transactional customer-facing applications to prevent exploitation of weakened algorithms or protocols; (d) the expansion of IT asset inventory to include all cryptographic tools and algorithms in use with pertinent information on the rationale for each cryptographic method employed and its mapping to supported application systems; and (e) the development and testing of compromise-recovery plans in the event of a cryptographic key compromise. This must set out the escalation process, procedures for keys regeneration, interim measures, changes to business-as-usual protocols and containment strategies or options to minimise the impact of a compromise.	Functional	Intersects With	Cryptographic Cipher Suites and Protocols Inventory	CRY-01.5	Mechanisms exist to identify, document and review deployed cryptographic cipher suites and protocols to proactively respond to industry trends regarding the continued viability of utilized cryptographic cipher suites and protocols.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.20	Cryptography	A financial institution must establish a robust and resilient cryptography policy to promote the adoption of strong cryptographic controls for protection of important data and information. This policy, at a minimum, shall address requirements for- (a) the adoption of industry standards for encryption algorithms, message authentication, hash functions, digital signatures and random number generation; (b) the adoption of robust and secure processes in managing cryptographic key lifecycles which include generation, distribution, renewal, usage, storage, recovery, revocation and destruction; (c) the periodic review, at least annually, of all cryptographic standards and algorithms currently in use for critical systems, external linked or transactional customer-facing applications to prevent exploitation of weakened algorithms or protocols; (d) the expansion of IT asset inventory to include all cryptographic tools and algorithms in use with pertinent information on the rationale for each cryptographic method employed and its mapping to supported application systems; and (e) the development and testing of compromise-recovery plans in the event of a cryptographic key compromise. This must set out the escalation process, procedures for keys regeneration, interim measures, changes to business-as-usual protocols and containment strategies or options to minimise the impact of a compromise.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	5	
10.20	Cryptography	A financial institution must establish a robust and resilient cryptography policy to promote the adoption of strong cryptographic controls for protection of important data and information. This policy, at a minimum, shall address requirements for- (a) the adoption of industry standards for encryption algorithms, message authentication, hash functions, digital signatures and random number generation; (b) the adoption of robust and secure processes in managing cryptographic key lifecycles which include generation, distribution, renewal, usage, storage, recovery, revocation and destruction; (c) the periodic review, at least annually, of all cryptographic standards and algorithms currently in use for critical systems, external linked or transactional customer-facing applications to prevent exploitation of weakened algorithms or protocols; (d) the expansion of IT asset inventory to include all cryptographic tools and algorithms in use with pertinent information on the rationale for each cryptographic method employed and its mapping to supported application systems; and (e) the development and testing of compromise-recovery plans in the event of a cryptographic key compromise. This must set out the escalation process, procedures for keys regeneration, interim measures, changes to business-as-usual protocols and containment strategies or options to minimise the impact of a compromise.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
10.21	Cryptography	A financial institution must conduct due diligence and evaluate the cryptographic controls associated with the technology used in order to protect the confidentiality, integrity, authentication, authorisation and non-repudiation of information. Additionally, a financial institution must ensure the following: (a) except for non-critical systems or applications that do not contain customer information, the financial institution must retain ownership and control of the encryption keys (themselves or with an independent key custodian) to minimize the risk of unauthorised access to the data; (b) where the financial institution does not generate its own encryption keys, the financial institution shall undertake appropriate measures to ensure robust controls and processes are in place to manage encryption keys securely including adhere to relevant industry standard; (c) where this involves a reliance on third party assessments, the financial institution shall consider whether such reliance is consistent with the financial institution's risk appetite and tolerance; and (d) the financial institution must also give due regard to the system resources required to support the cryptographic controls and the risk of reduced network traffic visibility of data that has been encrypted.	Functional	Intersects With	Defensible Evidence of Due Diligence	CPL-13.1	Mechanisms exist to produce evidence of due diligence activities performed, capable of withstanding external audit or regulatory scrutiny.	5	
10.21	Cryptography	A financial institution must conduct due diligence and evaluate the cryptographic controls associated with the technology used in order to protect the confidentiality, integrity, authentication, authorisation and non-repudiation of information. Additionally, a financial institution must ensure the following: (a) except for non-critical systems or applications that do not contain customer information, the financial institution must retain ownership and control of the encryption keys (themselves or with an independent key custodian) to minimize the risk of unauthorised access to the data; (b) where the financial institution does not generate its own encryption keys, the financial institution shall undertake appropriate measures to ensure robust controls and processes are in place to manage encryption keys securely including adhere to relevant industry standard; (c) where this involves a reliance on third party assessments, the financial institution shall consider whether such reliance is consistent with the financial institution's risk appetite and tolerance; and (d) the financial institution must also give due regard to the system resources required to support the cryptographic controls and the risk of reduced network traffic visibility of data that has been encrypted.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	5	
10.22	Cryptography	A financial institution must ensure cryptographic controls are based on the effective implementation of suitable cryptographic protocols. The protocols shall include secret and public cryptographic key protocols, both of which shall reflect a high degree of protection to the applicable secret or private cryptographic keys. The selection of such protocols must be based on recognised international standards and tested accordingly. Commensurate with the level of risk, secret cryptographic key and private-cryptographic key storage and encryption / decryption computation must be undertaken in a protected environment, supported by a hardware security module (HSM), trusted execution environment (TEE) or similarly secured devices.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.22	Cryptography	A financial institution must ensure cryptographic controls are based on the effective implementation of suitable cryptographic protocols. The protocols shall include secret and public cryptographic key protocols, both of which shall reflect a high degree of protection to the applicable secret or private cryptographic keys. The selection of such protocols must be based on recognised international standards and tested accordingly. Commensurate with the level of risk, secret cryptographic key and private-cryptographic key storage and encryption / decryption computation must be undertaken in a protected environment, supported by a hardware security module (HSM), trusted execution environment (TEE) or similarly secured devices.	Functional	Intersects With	Cryptographic Cipher Suites and Protocols Inventory	CRY-01.5	Mechanisms exist to identify, document and review deployed cryptographic cipher suites and protocols to proactively respond to industry trends regarding the continued viability of utilized cryptographic cipher suites and protocols.	3	
10.22	Cryptography	A financial institution must ensure cryptographic controls are based on the effective implementation of suitable cryptographic protocols. The protocols shall include secret and public cryptographic key protocols, both of which shall reflect a high degree of protection to the applicable secret or private cryptographic keys. The selection of such protocols must be based on recognised international standards and tested accordingly. Commensurate with the level of risk, secret cryptographic key and private-cryptographic key storage and encryption / decryption computation must be undertaken in a protected environment, supported by a hardware security module (HSM), trusted execution environment (TEE) or similarly secured devices.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
10.23	Cryptography	A financial institution shall store public cryptographic keys in a certificate issued by a Certificate Authority, as appropriate to the level of risk. Such certificates associated with customers shall be issued by recognised Certificate Authorities. The financial institution must ensure that the implementation of authentication and signature protocols using such certificates are subject to strong protection to ensure that the use of private cryptographic keys corresponding to the user certificates are legally binding and irrefutable. The initial issuance and subsequent renewal of such certificates must be consistent with industry best practices and applicable legal / regulatory specifications.	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	
10.24	Data Centre Resilience	A financial institution must specify the resilience and availability objectives of its data centres to effectively support its business recovery objectives.	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	
10.24	Data Centre Resilience	A financial institution must specify the resilience and availability objectives of its data centres to effectively support its business recovery objectives.	Functional	Intersects With	Recovery Operations Criteria	BCD-01.5	Mechanisms exist to define specific criteria that must be met to initiate Business Continuity / Disaster Recover (BC/DR) plans that facilitate business continuity operations capable of meeting applicable Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	8	
10.24	Data Centre Resilience	A financial institution must specify the resilience and availability objectives of its data centres to effectively support its business recovery objectives.	Functional	Intersects With	Achieving Resilience Requirements	SEA-01.2	Mechanisms exist to achieve resilience requirements in normal and adverse situations.	8	
10.24	Data Centre Resilience	A financial institution must specify the resilience and availability objectives of its data centres to effectively support its business recovery objectives.	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	8	
10.24	Data Centre Resilience	A financial institution must specify the resilience and availability objectives of its data centres to effectively support its business recovery objectives.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets.	5	
10.25	Data Centre Resilience	A financial institution must ensure data centres have redundant capacity components and multiple distribution paths serving the computer equipment to eliminate any single point of failure for effective achievement of the identified business recovery objectives.	Functional	Intersects With	Continue Essential Mission & Business Functions	BCD-02.2	Mechanisms exist to continue essential missions and business functions with little or no loss of operational continuity and sustain that continuity until full system restoration at primary processing and/or	8	
10.25	Data Centre Resilience	A financial institution must ensure data centres have redundant capacity components and multiple distribution paths serving the computer equipment to eliminate any single point of failure for effective achievement of the identified business recovery objectives.	Functional	Intersects With	Redundant Secondary System	BCD-11.7	Mechanisms exist to maintain a failover capability, which is not collocated with the primary Technology Asset, Application and/or Service (TAAS), which can be activated with little-to-no loss of information or disruption to operations.	8	
10.25	Data Centre Resilience	A financial institution must ensure data centres have redundant capacity components and multiple distribution paths serving the computer equipment to eliminate any single point of failure for effective achievement of the identified business recovery objectives.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
10.25	Data Centre Resilience	A financial institution must ensure data centres have redundant capacity components and multiple distribution paths serving the computer equipment to eliminate any single point of failure for effective achievement of the identified business recovery objectives.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	8	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no	Functional	Intersects With	Continue Essential Mission & Business Functions	BCD-02.2	Mechanisms exist to continue essential missions and business functions with little or no loss of operational continuity and sustain that continuity until full system restoration at primary processing and/or storage sites.	8	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Redundant Secondary System	BCD-11.7	Mechanisms exist to maintain a failover capability, which is not collocated with the primary Technology Asset, Application and/or Service (TAAS), which can be activated with little-to-no loss of information or disruption to operations.	5	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Maintenance Operations	MNT-01	Mechanisms exist to develop, disseminate, review & update procedures to facilitate the implementation of maintenance controls across the enterprise.	5	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Controlled Maintenance	MNT-02	Mechanisms exist to conduct controlled maintenance activities throughout the lifecycle of the Technology Asset, Application and/or Service (TAAS).	5	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
10.26	Data Centre Resilience	A financial institution shall host critical systems in a dedicated space intended for production data centre usage. The dedicated space must be physically secured from unauthorised access and is not located in a disaster-prone area. A financial institution must also ensure there is no single point of failure in the design and connectivity for critical components of the production data centres, including hardware components, electrical utility, thermal management and data centre infrastructure. A financial institution must also ensure adequate maintenance, and holistic and continuous monitoring of these critical components with timely alerts on faults and indicators of potential issues.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	8	
10.27	Data Centre Resilience	A financial institution must establish adequate control procedures for its data centre operations, including the deployment of relevant automated tools for batch processing management to ensure timely and accurate batch processes. These control procedures shall also include procedures for implementing changes in the production system, error handling as well as management of other exceptional conditions.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	
10.27	Data Centre Resilience	A financial institution must establish adequate control procedures for its data centre operations, including the deployment of relevant automated tools for batch processing management to ensure timely and accurate batch processes. These control procedures shall also include procedures for implementing changes in the production system, error handling as well as management of other exceptional conditions.	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	8	
10.28	Data Centre Resilience	A financial institution must segregate incompatible activities in the data centre operations environment to prevent any unauthorised activity. In the case where vendors' or programmers' access to the production environment is necessary, these activities must be properly authorised and monitored.	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	
10.28	Data Centre Resilience	A financial institution must segregate incompatible activities in the data centre operations environment to prevent any unauthorised activity. In the case where vendors' or programmers' access to the production environment is necessary, these activities must be properly authorised and monitored.	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	8	
10.29	Service Availability	A financial institution must ensure its system capacity needs are well-planned and managed with due regard to peak processing period, business growth plans and technology architecture changes.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	
10.29	Service Availability	A financial institution must ensure its system capacity needs are well-planned and managed with due regard to peak processing period, business growth plans and technology architecture changes.	Functional	Intersects With	Resource Priority	CAP-02	Mechanisms exist to control resource utilization of Technology Assets, Applications and/or Services (TAAS) that are susceptible to Denial of Service (DoS) attacks to limit and prioritize the use of resources.	5	
10.29	Service Availability	A financial institution must ensure its system capacity needs are well-planned and managed with due regard to peak processing period, business growth plans and technology architecture changes.	Functional	Intersects With	Capacity Planning	CAP-03	Mechanisms exist to conduct capacity planning so that necessary capacity for information processing, telecommunications and environmental support will exist during contingency operations.	5	
10.29	Service Availability	A financial institution must ensure its system capacity needs are well-planned and managed with due regard to peak processing period, business growth plans and technology architecture changes.	Functional	Intersects With	Elastic Expansion	CAP-05	Mechanisms exist to automatically scale the resources available for Technology Assets, Applications and/or Services (TAAS), as demand conditions change.	3	
10.30	Service Availability	A financial institution must establish real-time monitoring mechanisms to track capacity utilisation and performance of key processes and services. These monitoring mechanisms shall be capable of providing actionable	Functional	Subset Of	Performance Monitoring	CAP-04	Automated mechanisms exist to centrally-monitor and alert on the operating state and health status of critical Technology Assets, Applications and/or Services (TAAS).	10	
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake;	5	
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or warning of service degradation or intermittent failures. This means the capability to: (i) detect failed transactions and measure service availability more accurately; (ii) monitor the number of affected customers and transaction volumes during service disruptions to measure the extent and	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or warning of service degradation or intermittent failures. This means the capability to: (i) detect failed transactions and measure service availability more accurately; (ii) monitor the number of affected customers and transaction volumes during service disruptions to measure the extent and severity of customer impact; and (iii) immediately escalate to senior management when service disruptions affect 5% or more of expected daily customers or transaction volumes; (b) conduct regular reviews to identify and mitigate potentially vulnerable IT system interdependencies to prevent simultaneous interruptions to multiple digital services or delivery channels; and (c) establish stand-in processing arrangement by 30 September 2027 and deploy such arrangement during disruptions to ensure continuity of services during disruptions. A financial institution shall prioritise deployment of this capability for digital services and delivery channels which are least substitutable, and ensure its customers are well informed on the terms of use (such as the transaction limit), associated risks and allocation of responsibilities between parties and mitigation actions against fraud risks.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or warning of service degradation or intermittent failures. This means the capability to: (i) detect failed transactions and measure service availability more accurately; (ii) monitor the number of affected customers and transaction volumes during service disruptions to measure the extent and severity of customer impact; and (iii) immediately escalate to senior management when service disruptions affect 5% or more of expected daily customers or transaction volumes; (b) conduct regular reviews to identify and mitigate potentially vulnerable IT system interdependencies to prevent simultaneous interruptions to multiple digital services or delivery channels; and (c) establish stand-in processing arrangement by 30 September 2027 and deploy such arrangement during disruptions to ensure continuity of services during disruptions. A financial institution shall prioritise deployment of this capability for digital services and delivery channels which are least substitutable, and ensure its customers are well informed on the terms of use (such as the transaction limit), associated risks and allocation of responsibilities between parties and mitigation actions against fraud risks.	Functional	Intersects With	Achieving Resilience Requirements	SEA-01.2	Mechanisms exist to achieve resilience requirements in normal and adverse situations.	5	
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or warning of service degradation or intermittent failures. This means the capability to: (i) detect failed transactions and measure service availability more accurately; (ii) monitor the number of affected customers and transaction volumes during service disruptions to measure the extent and severity of customer impact; and (iii) immediately escalate to senior management when service disruptions affect 5% or more of expected daily customers or transaction volumes; (b) conduct regular reviews to identify and mitigate potentially vulnerable IT system interdependencies to prevent simultaneous interruptions to multiple digital services or delivery channels; and (c) establish stand-in processing arrangement by 30 September 2027 and deploy such arrangement during disruptions to ensure continuity of services during disruptions. A financial institution shall prioritise deployment of this capability for digital services and delivery channels which are least substitutable, and ensure its customers are well informed on the terms of use (such as the transaction limit), associated risks and allocation of responsibilities between parties and mitigation actions against fraud risks.	Functional	Intersects With	Resilience Capabilities	SEA-01.3	Mechanisms exist to ensure security, compliance and resilience are designed and implemented to provide resistance to: (1) Unintentional errors (by users or software); and (2) Intentional attack or circumvention.	5	
10.31	Service Availability	A financial institution shall enhance the resilience of key digital services and delivery channels through the following measures: (a) implement effective mechanisms by 30 September 2027 to provide early signals or warning of service degradation or intermittent failures. This means the capability to: (i) detect failed transactions and measure service availability more accurately; (ii) monitor the number of affected customers and transaction volumes during service disruptions to measure the extent and severity of customer impact; and (iii) immediately escalate to senior management when service disruptions affect 5% or more of expected daily customers or transaction volumes; (b) conduct regular reviews to identify and mitigate potentially vulnerable IT system interdependencies to prevent simultaneous interruptions to multiple digital services or delivery channels; and (c) establish stand-in processing arrangement by 30 September 2027 and deploy such arrangement during disruptions to ensure continuity of services during disruptions. A financial institution shall prioritise deployment of this capability for digital services and delivery channels which are least substitutable, and ensure its customers are well informed on the terms of use (such as the transaction limit), associated risks and allocation of responsibilities between parties and mitigation actions against fraud risks.	Functional	Intersects With	Vulnerability & Patch Management Program (VPM ²)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	5	
10.32	Service Availability	For critical systems, where there is a reasonable expectation for immediate delivery of service to customers or dealings with counterparties, a financial institution must ensure that these systems are designed for high availability with a cumulative unplanned downtime affecting the interface with customers or counterparties of not more than 4 hours on a rolling 12 months basis and a maximum tolerable downtime of 120 minutes per incident.	Functional	Intersects With	Recovery Time / Point Objectives (RTO / RPO)	BCD-01.4	Mechanisms exist to facilitate recovery operations in accordance with Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.32	Service Availability	For critical systems, where there is a reasonable expectation for immediate delivery of service to customers or dealings with counterparties, a financial institution must ensure that these systems are designed for high availability with a cumulative unplanned downtime affecting the interface with customers or counterparties of not more than 4 hours on a rolling 12 months basis and a maximum tolerable downtime of 120 minutes per incident.	Functional	Intersects With	Recovery Operations Criteria	BCD-01.5	Mechanisms exist to define specific criteria that must be met to initiate Business Continuity / Disaster Recover (BC/DR) plans that facilitate business continuity operations capable of meeting applicable Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
10.32	Service Availability	For critical systems, where there is a reasonable expectation for immediate delivery of service to customers or dealings with counterparties, a financial institution must ensure that these systems are designed for high availability with a cumulative unplanned downtime affecting the interface with customers or counterparties of not more than 4 hours on a rolling 12 months basis and a maximum tolerable downtime of 120 minutes per incident.	Functional	Intersects With	Achieving Resilience Requirements	SEA-01.2	Mechanisms exist to achieve resilience requirements in normal and adverse situations.	5	
10.32	Service Availability	For critical systems, where there is a reasonable expectation for immediate delivery of service to customers or dealings with counterparties, a financial institution must ensure that these systems are designed for high availability with a cumulative unplanned downtime affecting the interface with customers or counterparties of not more than 4 hours on a rolling 12 months basis and a maximum tolerable downtime of 120 minutes per incident.	Functional	Intersects With	Resilience Capabilities	SEA-01.3	Mechanisms exist to ensure security, compliance and resilience are designed and implemented to provide resistance to: (1) Unintentional errors (by users or software); and (2) Intentional attack or circumvention.	5	
10.33	Service Availability	Eligible e-money issuers, non-bank registered merchant acquirers and intermediary remittance institutions that have not been designated as a National Critical Information Infrastructure (NCII) entity are encouraged to implement the measures provided in paragraph 10.31.	Functional	No Relationship	N/A	N/A	N/A	0	
10.34	Service Availability	A financial institution shall prioritise diversity in technology to enhance resilience by ensuring critical systems infrastructure are not excessively exposed to similar technology risks.	Functional	No Relationship	N/A	N/A	N/A	0	
10.35	Service Availability	During an interruption of digital services or delivery channels, including periods of performance degradation or intermittent failures, a financial institution shall respond promptly and effectively to minimise the impact on its customers. This includes but not limited to- (a) ensure timely	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
10.35	Service Availability	During an interruption of digital services or delivery channels, including periods of performance degradation or intermittent failures, a financial institution shall respond promptly and effectively to minimise the impact on its customers. This includes but not limited to- (a) ensure timely escalation and decision-making to resume services promptly via alternative arrangements and stabilise performance within the timeframe specified in paragraph 10.32 under all plausible scenarios; (b) define clear	Functional	Intersects With	Grievances	CPL-07	Mechanisms exist to govern the intake and analysis of grievances related to the organization's cybersecurity and/or data protection practices.	5	
10.35	Service Availability	During an interruption of digital services or delivery channels, including periods of performance degradation or intermittent failures, a financial institution shall respond promptly and effectively to minimise the impact on its customers. This includes but not limited to- (a) ensure timely escalation and decision-making to resume services promptly via alternative arrangements and stabilise performance within the timeframe specified in paragraph 10.32 under all plausible scenarios; (b) define clear accountabilities for managing performance degradation issues and formalise arrangements with third party service providers to ensure effective coordination and timely recovery to normal performance levels; (c) establish a communication plan for service interruptions to immediately inform affected customers, properly manage a high volume of customer feedback, and provide frequent updates on recovery efforts, as well as actionable information on available alternatives for customers with urgent needs; (d) provide customers with a convenient means of checking the availability of digital services, which may include publishing real-time availability and performance status of its digital services on the corporate website; and (e) disclose the track record of service availability on a quarterly basis within 15 calendar days of quarter-end, beginning from 15 October 2027.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
10.35	Service Availability	During an interruption of digital services or delivery channels, including periods of performance degradation or intermittent failures, a financial institution shall respond promptly and effectively to minimise the impact on its customers. This includes but not limited to- (a) ensure timely escalation and decision-making to resume services promptly via alternative arrangements and stabilise performance within the timeframe specified in paragraph 10.32 under all plausible scenarios; (b) define clear accountabilities for managing performance degradation issues and formalise arrangements with third party service providers to ensure effective coordination and timely recovery to normal performance levels; (c) establish a communication plan for service interruptions to immediately inform affected customers, properly manage a high volume of customer feedback, and provide frequent updates on recovery efforts, as well as actionable information on available alternatives for customers with urgent needs; (d) provide customers with a convenient means of checking the availability of digital services, which may include publishing real-time availability and performance status of its digital services on the corporate website; and (e) disclose the track record of service availability on a quarterly basis within 15 calendar days of quarter-end, beginning from 15 October 2027.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
10.36	Network Resilience	A financial institution must design and implement a reliable, scalable and secure enterprise network that is able to support its business activities, including future growth plans.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.36	Network Resilience	A financial institution must design and implement a reliable, scalable and secure enterprise network that is able to support its business activities, including future growth plans.	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF); (2) Sherwood Applied Business Security Architecture (SABSA); and/or (3) An organization-defined reference architecture.	8	
10.36	Network Resilience	A financial institution must design and implement a reliable, scalable and secure enterprise network that is able to support its business activities, including future growth plans.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	8	
10.37	Network Resilience	A financial institution must ensure the network services for its critical systems are reliable and have no single point of failure in order to protect the critical systems against potential network faults and cyber threats.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	8	
10.37	Network Resilience	A financial institution must ensure the network services for its critical systems are reliable and have no single point of failure in order to protect the critical systems against potential network faults and cyber threats.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	8	
10.37	Network Resilience	A financial institution must ensure the network services for its critical systems are reliable and have no single point of failure in order to protect the critical systems against potential network faults and cyber threats.	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF);	8	
10.38	Network Resilience	The control measures to prevent from network faults as referred to in paragraph 10.37 are expected to include component redundancy, service diversity and alternate network paths.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	
10.38	Network Resilience	The control measures to prevent from network faults as referred to in paragraph 10.37 are expected to include component redundancy, service diversity and alternate network paths.	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF); (2) Sherwood Applied Business Security Architecture (SABSA); and/or (3) An organization-defined reference architecture.	5	
10.39	Network Resilience	A financial institution must establish real-time network bandwidth monitoring processes and corresponding network service resilience metrics to flag any over utilisation of bandwidth and system disruptions due to bandwidth congestion and network faults. This includes traffic analysis to detect trends and anomalies.	Functional	Intersects With	Performance Monitoring	CAP-04	Automated mechanisms exist to centrally-monitor and alert on the operating state and health status of critical Technology Assets, Applications and/or Services (TAAS).	5	
10.40	Network Resilience	A financial institution must ensure network services supporting critical systems are designed and implemented to ensure the confidentiality, integrity and availability of data.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	
10.40	Network Resilience	A financial institution must ensure network services supporting critical systems are designed and implemented to ensure the confidentiality, integrity and availability of data.	Functional	Intersects With	Achieving Resilience Requirements	SEA-01.2	Mechanisms exist to achieve resilience requirements in normal and adverse situations.	5	
10.40	Network Resilience	A financial institution must ensure network services supporting critical systems are designed and implemented to ensure the confidentiality, integrity and availability of data.	Functional	Intersects With	Resilience Capabilities	SEA-01.3	Mechanisms exist to ensure security, compliance and resilience are designed and implemented to provide resistance to: (1) Unintentional errors (by users or software); and (2) Intentional attack or circumvention.	5	
10.40	Network Resilience	A financial institution must ensure network services supporting critical systems are designed and implemented to ensure the confidentiality, integrity and availability of data.	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from:	5	
10.40	Network Resilience	A financial institution must ensure network services supporting critical systems are designed and implemented to ensure the confidentiality, integrity and availability of data.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	
10.41	Network Resilience	A financial institution must establish and maintain a network design blueprint identifying all of its internal and external network interfaces and connectivity. The blueprint must highlight both physical and logical connectivity between network components and network segmentations.	Functional	Subset Of	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	10	
10.42	Network Resilience	A financial institution must ensure sufficient and relevant network device logs are retained for investigations and forensic purposes for at least three years.	Functional	Subset Of	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	10	
10.43	Network Resilience	A financial institution must implement appropriate safeguards to minimise the risk of a system compromise in one entity affecting other entities within the group. Safeguards implemented may include establishing logical network segmentation for the financial institution from other entities within the group.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall: (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR)	10	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall: (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Testing for Reliability & Integrity	BCD-11.1	Mechanisms exist to routinely test backups that verify the reliability of the backup process, as well as the integrity and availability of the data.	5	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Separate Storage for Critical Information	BCD-11.2	Mechanisms exist to store backup copies of critical software and other security-related information in a separate facility or in a fire-rated container that is not collocated with the system being backed up.	5	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Media Storage	DCH-06	Mechanisms exist to: (1) Physically control and securely store digital and non-digital media within controlled areas using organization-defined security measures; and (2) Protect system media until the media are destroyed or sanitized using approved equipment, techniques and procedures.	5	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Physically Secure All Media	DCH-06.1	Mechanisms exist to physically secure all media that contains sensitive information.	5	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	5	
10.44	System Backup and Restoration	A financial institution must establish a robust backup strategy and procedures to meet business recovery objectives. At a minimum, a financial institution shall- (a) establish backup and restoration procedures to effectively manage the backup data life cycle; (b) maintain an adequate number of backup copies of all critical data, the updated version of the operating system software, production programs, system utilities, all master and transaction files and event logs for recovery purposes; (c) backup media must be stored in an environmentally secure and access-controlled backup site; (d) secure the storage and transportation of sensitive data in removable media to meet minimum controls as specified in Appendix 1 or equivalent; (e) test backup and restoration procedures periodically to validate recovery capabilities. Remedial actions shall be taken promptly by the financial institution to fix the root cause of unsuccessful backups; and (f) undertake an independent risk assessment of its end-to-end backup storage and delivery management to ensure that existing controls are adequate in protecting sensitive data at all times.	Functional	Intersects With	Business Impact Analysis (BIA)	RSK-08	Mechanisms exist to conduct a Business Impact Analysis (BIA) to identify and assess security, compliance and resilience risks.	5	
10.45	System Backup and Restoration	A financial institution shall establish a tamper-proof backup arrangement and an isolated recovery environment to enable timely resumption of critical banking and payment services within its tolerable level in the event of destructive cyber-attacks such as widespread data loss caused by ransomware.	Functional	Intersects With	Cryptographic Protection	BCD-11.4	Cryptographic mechanisms exist to prevent the unauthorized disclosure and/or modification of backup information.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.45	System Backup and Restoration	A financial institution shall establish a tamper-proof backup arrangement and an isolated recovery environment to enable timely resumption of critical banking and payment services within its tolerable level in the event of destructive cyber-attacks such as widespread data loss caused by ransomware.	Functional	Intersects With	Technology Assets, Applications and/or Services (TAAS) Recovery & Reconstitution	BCD-12	Mechanisms exist to ensure the secure recovery and reconstitution of Technology Assets, Applications and/or Services (TAAS) to a known state after a disruption, compromise or failure.	5	
10.45	System Backup and Restoration	A financial institution shall establish a tamper-proof backup arrangement and an isolated recovery environment to enable timely resumption of critical banking and payment services within its tolerable level in the event of destructive cyber-attacks such as widespread data loss caused by ransomware.	Functional	Intersects With	Isolated Recovery Environment	BCD-14	Mechanisms exist to utilize an isolated, non-production environment to perform data backup and recovery operations through offline, cloud or off-site capabilities.	8	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security	Functional	Intersects With	Third-Party Criticality Assessments	TPM-02	Mechanisms exist to identify, prioritize and assess suppliers and partners of critical Technology Assets, Applications and/or Services (TAAS) using a supply chain risk assessment process relative to their importance in supporting the delivery of high-value services.	8	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security and reliability of technology services in compliance with all relevant regulatory requirements prescribed in this policy document.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	8	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security and reliability of technology services in compliance with all relevant regulatory requirements prescribed in this policy document.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security and reliability of technology services in compliance with all relevant regulatory requirements prescribed in this policy document.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCII) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCII) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
10.46	Third Party Service Provider Management	The board and senior management of the financial institution must exercise effective oversight and address associated risks when engaging third party service providers for critical technology functions and systems. The financial institution remains accountable for managing all risks that arise from engagement of third party service providers, to ensure security and reliability of technology services in compliance with all relevant regulatory requirements prescribed in this policy document.	Functional	Intersects With	Third-Party Scope Review	TPM-05.5	Mechanisms exist to perform recurring validation of the Responsible, Accountable, Supportive, Consulted & Informed (RASCII) matrix, or similar documentation, to ensure security, compliance and resilience control assignments accurately reflect current: (1) Contractual obligations for the External Service Provider (ESP); (2) Business practices; (3) Applicable stakeholders; and (4) Deployed Technology Assets, Applications and/or Services (TAAS).	5	
10.47	Third Party Service Provider Management	A financial institution must conduct a due diligence on a third party service provider prior to its on-boarding or engagement and throughout the service engagement to ensure achievement of business performance and recovery objectives remain unimpaired, considering the latest risk environment. At the minimum, a financial institution must consider the range of risks outlined in Appendix 8.	Functional	Subset Of	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	10	
10.48	Third Party Service Provider Management	A financial institution must establish a Service Level Agreement (SLA) when engaging third party service provider. At a minimum, the SLA shall contain the following: (a) access rights for the regulator and any party appointed by the financial institution to examine any activity or entity of the financial institution; (b) requirements for the third party service provider to provide sufficient prior notice to financial institutions of any sub-contracting which is substantial; (c) a written undertaking by the third party service provider on its compliance with secrecy provisions under relevant legislations; (d) arrangements for disaster recovery and backup capability, where applicable; (e) service level objectives for uptime or availability; (f)	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
10.48	Third Party Service Provider Management	A financial institution must establish a Service Level Agreement (SLA) when engaging third party service provider. At a minimum, the SLA shall contain the following: (a) access rights for the regulator and any party appointed by the financial institution to examine any activity or entity of the financial institution; (b) requirements for the third party service provider to provide sufficient prior notice to financial institutions of any sub-contracting which	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
10.49	Third Party Service Provider Management	A financial institution must formulate a roadmap to achieve continuous monitoring of a third party service provider's cybersecurity posture to obtain real-time insights for effective incident management. The financial institution shall undertake the following: (a) measure the IT infrastructure footprint and the customer information accessible to third parties, and regularly manage this external stress state exposures to mitigate cyber-attack surfaces; (b) adopt leading security policies and controls to mitigate product-specific third party risks; (c) ensure incident response plans incorporate protocols with third party service providers to detect and contain adverse impact of security vulnerabilities resulting from software updates; (d) define a priority set of security controls that require more frequent assurance assertion from the third party service providers; (e) monitor technology and cyber incidents information disclosed by third party service providers at a higher frequency; (f) implement technology solutions to automate metric testing; and (g) establish processes to respond to breached thresholds, including investigating failed assertions and remedying control gaps.	Functional	Intersects With	Security Compromise Notification Agreements	TPM-05.1	Mechanisms exist to compel External Service Providers (ESPs) to provide notification of actual or potential compromises in the supply chain that can potentially affect or have adversely affected Technology Assets, Applications and/or Services (TAAS) that the organization utilizes.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.48	Third Party Service Provider Management	A financial institution must establish a Service Level Agreement (SLA) when engaging third party service provider. At a minimum, the SLA shall contain the following: (a) access rights for the regulator and any party appointed by the financial institution to examine any activity or entity of the financial institution; (b) requirements for the third party service provider to provide sufficient prior notice to financial institutions of any sub-contracting which is substantial; (c) a written undertaking by the third party service provider on its compliance with secrecy provisions under relevant legislations; (d) arrangements for disaster recovery and backup capability, where applicable; (e) service level objectives for uptime or availability; (f) arrangements to secure business continuity in the event of an exit or termination of the third party service provider, which includes ensuring data residing in third party service providers are recoverable in a timely manner; (g) responsibility of third party service providers to promptly disclose and notify the financial institution of any service disruptions or cyber incidents that affect the financial institution or its customer data; (h) requirements for the third party service providers to comply with the relevant internationally recognised standards and ensure their key staff keep their skills up-to-date with the relevant certifications; and (i) requirements for third party service providers to participate in the financial institution's security awareness and education program, where appropriate.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	5	
10.48	Third Party Service Provider Management	A financial institution must establish a Service Level Agreement (SLA) when engaging third party service provider. At a minimum, the SLA shall contain the following: (a) access rights for the regulator and any party appointed by the financial institution to examine any activity or entity of the financial institution; (b) requirements for the third party service provider to provide sufficient prior notice to financial institutions of any sub-contracting which is substantial; (c) a written undertaking by the third party service provider on its compliance with secrecy provisions under relevant legislations; (d) arrangements for disaster recovery and backup capability, where applicable; (e) service level objectives for uptime or availability; (f) arrangements to secure business continuity in the event of an exit or termination of the third party service provider, which includes ensuring data residing in third party service providers are recoverable in a timely manner; (g) responsibility of third party service providers to promptly disclose and notify the financial institution of any service disruptions or cyber incidents that affect the financial institution or its customer data; (h) requirements for the third party service providers to comply with the relevant internationally recognised standards and ensure their key staff	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASC) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASC) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
10.49	Third Party Service Provider Management	A financial institution must formulate a roadmap to achieve continuous monitoring of a third party service provider's cybersecurity posture to obtain real-time insights for effective incident management. The financial institution shall undertake the following: (a) measure the IT infrastructure footprint and the customer information accessible to third parties, and regularly manage this external stress state exposures to mitigate cyber-attack surfaces; (b) adopt leading security policies and controls to mitigate product-specific third party risks; (c) ensure incident response plans incorporate protocols with third party service providers to detect and contain adverse impact of security vulnerabilities resulting from software updates; (d) define a priority set of security controls that require more frequent assurance assertion from the third party service providers; (e) monitor technology and cyber incidents information disclosed by third party service providers at a higher frequency; (f) implement technology solutions to automate metric testing; and (g) establish processes to respond to breached thresholds, including investigating failed assertions and remedying control gaps.	Functional	Intersects With	Monitoring for Third-Party Information Disclosure	TPM-07	Mechanisms exist to monitor for evidence of unauthorized exfiltration or disclosure of organizational information.	3	
10.49	Third Party Service Provider Management	A financial institution must formulate a roadmap to achieve continuous monitoring of a third party service provider's cybersecurity posture to obtain real-time insights for effective incident management. The financial institution shall undertake the following: (a) measure the IT infrastructure footprint and the customer information accessible to third parties, and regularly manage this external stress state exposures to mitigate cyber-attack surfaces; (b) adopt leading security policies and controls to mitigate product-specific third party risks; (c) ensure incident response plans incorporate protocols with third party service providers to detect and contain adverse impact of security vulnerabilities resulting from software updates; (d) define a priority set of security controls that require more frequent assurance assertion from the third party service providers; (e) monitor technology and cyber incidents information disclosed by third party service providers at a higher frequency; (f) implement technology solutions to automate metric testing; and (g) establish processes to respond to breached thresholds, including investigating failed assertions and remedying control gaps.	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	3	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Cloud Security Architecture	CLD-02	Mechanisms exist to ensure the cloud security architecture supports the organization's technology strategy to securely design, configure and maintain cloud employments.	8	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Multi-Tenant Environments	CLD-06	Mechanisms exist to ensure multi-tenant owned or managed assets (physical and virtual) are designed and governed such that provider and customer (tenant) user access is appropriately segmented from other tenant users.	8	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Customer Responsibility Matrix (CRM)	CLD-06.1	Mechanisms exist to formally document a Customer Responsibility Matrix (CRM), delineating assigned responsibilities for security, compliance and resilience controls between the Cloud Service Provider (CSP) and its customers.	8	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Geolocation Requirements for Processing, Storage and Service Locations	CLD-09	Mechanisms exist to control the location of cloud processing/storage based on business requirements that includes statutory, regulatory and contractual obligations.	5	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Sensitive Data In Public Cloud Providers	CLD-10	Mechanisms exist to limit and manage the storage of sensitive and/or regulated data in public cloud providers.	5	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Subset Of	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Third-Party Processing, Storage and Service Locations	TPM-04.4	Mechanisms exist to restrict the location of information processing/storage based on business requirements.	5	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
10.50	Cloud Services	A financial institution must fully understand the inherent risk of adopting cloud services. In this regard, a financial institution shall conduct a comprehensive risk assessment prior to cloud adoption which considers the inherent architecture of cloud services that leverages on the sharing of resources and services across multiple tenants over the Internet. The assessment must specifically address risks associated with the following: (a) sophistication of the deployment model; (b) migration of existing systems to cloud infrastructure; (c) location of cloud infrastructure including potential geo-political risks and legal risks that may impede compliance with any legal or regulatory requirements; (d) multi-tenancy or data co-mingling; (e) vendor lock-in and application portability or interoperability; (f) ability to customise security configurations of the cloud infrastructure to ensure a high level of data and technology system protection; (g) exposure to cyber-attacks via cloud service providers; (h) termination of a cloud service provider including the ability to secure the financial institution's data following the termination; (i) demarcation of responsibilities, limitations and liability of the cloud service provider; and (j) ability to meet regulatory requirements and international standards on cloud computing on a continuing basis.	Functional	Intersects With	Break Clauses	TPM-05.7	Mechanisms exist to include "break clauses" within contracts for failure to meet contract criteria for security, compliance and/or resilience controls.	5	
10.51	Cloud Services	For critical systems hosted on a public cloud, a financial institution is expected to consider common key risks and control measures as specified in Appendix 10. A financial institution that relies on alternative risk management practices that depart from the measures outlined in Appendix 10 is expected to be prepared to explain and demonstrate to the Bank that these alternative practices are at least as effective as, or superior to, the measures in Appendix 10.	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.52	Cloud Services	A financial institution must implement appropriate safeguards on customer and counterparty information and proprietary data when using cloud services to protect against unauthorised disclosure and access. This shall include retaining ownership, control and management of all data pertaining to customer and counterparty information, proprietary data and services hosted on the cloud, including the relevant cryptographic keys management.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	
10.53	Access Control	A financial institution must implement an access control policy for the identification, authentication, and authorisation of all users to its IT assets and data. The level of granularity defined in the access control policy shall be commensurate with the level of risk of unauthorised access to its IT assets.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
10.54	Access Control	A financial institution shall adhere to the following principles: (a) adopt a "deny all" access control policy for users by default because all access to IT assets must be explicitly authorised; (b) employ "least privilege" access rights to ensure IT assets are accessed on a "need-to-have" basis where only the minimum sufficient permissions are granted to legitimate users to perform their roles; (c) employ time-bound access which restrict access to a specific period based on the nature of work; (d) employ segregation of	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
10.54	Access Control	A financial institution shall adhere to the following principles: (a) adopt a "deny all" access control policy for users by default because all access to IT assets must be explicitly authorised; (b) employ "least privilege" access rights to ensure IT assets are accessed on a "need-to-have" basis where only the minimum sufficient permissions are granted to legitimate users to perform their roles; (c) employ time-bound access which restrict access to a specific period based on the nature of work; (d) employ segregation of	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	
10.54	Access Control	A financial institution shall adhere to the following principles: (a) adopt a "deny all" access control policy for users by default because all access to IT assets must be explicitly authorised; (b) employ "least privilege" access rights to ensure IT assets are accessed on a "need-to-have" basis where only the minimum sufficient permissions are granted to legitimate users to	Functional	Intersects With	Least Functionality	CFG-03	Mechanisms exist to configure systems to provide only essential capabilities by specifically prohibiting or restricting the use of ports, protocols, and/or services.	5	
10.54	Access Control	A financial institution shall adhere to the following principles: (a) adopt a "deny all" access control policy for users by default because all access to IT assets must be explicitly authorised; (b) employ "least privilege" access rights to ensure IT assets are accessed on a "need-to-have" basis where only the minimum sufficient permissions are granted to legitimate users to perform their roles; (c) employ time-bound access which restrict access to a specific period based on the nature of work; (d) employ segregation of incompatible functions where no single person is responsible for an entire operation that may provide the ability to independently modify, circumvent, and disable system security features. This may include a combination of functions such as: (i) system development and technology operations; (ii) security administration and system administration; (iii) network operation and network security; and (iv) IT operations environment; (e) establish criteria for activities that require dual authorization control; and (f) adopt robust user authorization and authentication based on criticality of IT assets as follows: (i) stronger authentication for critical activities and higher-risk environment such as remote access; (ii) ensure user credentials provisioned with robust identity verification method to prevent impersonation risks; and (iii) ensure online credential is uniquely linked to a single user to ensure clear accountability in access to confidential IT assets.	Functional	Intersects With	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	5	
10.54	Access Control	A financial institution shall adhere to the following principles: (a) adopt a "deny all" access control policy for users by default because all access to IT assets must be explicitly authorised; (b) employ "least privilege" access rights to ensure IT assets are accessed on a "need-to-have" basis where only the minimum sufficient permissions are granted to legitimate users to perform their roles; (c) employ time-bound access which restrict access to a specific period based on the nature of work; (d) employ segregation of incompatible functions where no single person is responsible for an entire operation that may provide the ability to independently modify, circumvent, and disable system security features. This may include a combination of functions such as: (i) system development and technology operations; (ii) security administration and system administration; (iii) network operation and network security; and (iv) IT operations environment; (e) establish criteria for activities that require dual authorization control; and (f) adopt robust user authorization and authentication based on criticality of IT assets as follows: (i) stronger authentication for critical activities and higher-risk environment such as remote access; (ii) ensure user credentials provisioned with robust identity verification method to prevent impersonation risks; and (iii) ensure online credential is uniquely linked to a single user to ensure clear accountability in access to confidential IT assets.	Functional	Intersects With	Attribute-Based Access Control (ABAC)	IAC-29	Mechanisms exist to enforce Attribute-Based Access Control (ABAC) for policy-driven, dynamic authorizations that supports the secure sharing of information.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
10.55	Access Control	A financial institution must employ a multi-factor authentication (MFA) that can defend against social engineering attacks for authenticating user access to critical systems. The MFA must combine two or more of knowledge factors, inherent factors (e.g. biometric characteristics) or possession factors (e.g. security keys, tokens).	Functional	Subset Of	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/or (3) Non-console access to critical TAAS that store, transmit and/or process sensitive and/or regulated data.	10	
10.56	Access Control	A financial institution must establish a user access matrix to outline access rights, user roles or profiles, and the authorising and approving authorities. The access matrix must be periodically reviewed and updated.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
10.56	Access Control	A financial institution must establish a user access matrix to outline access rights, user roles or profiles, and the authorising and approving authorities. The access matrix must be periodically reviewed and updated.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	8	
10.56	Access Control	A financial institution must establish a user access matrix to outline access rights, user roles or profiles, and the authorising and approving authorities. The access matrix must be periodically reviewed and updated.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	8	
10.57	Access Control	A financial institution must ensure- (a) access controls to enterprise-wide systems are effectively managed and monitored; (b) anomalies are flagged for prompt investigations to contain any cyber incidents; and (c) user activities in critical systems are logged for audit and investigations. Activity	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	8	
10.57	Access Control	A financial institution must ensure- (a) access controls to enterprise-wide systems are effectively managed and monitored; (b) anomalies are flagged for prompt investigations to contain any cyber incidents; and (c) user activities in critical systems are logged for audit and investigations. Activity	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	8	
10.57	Access Control	A financial institution must ensure- (a) access controls to enterprise-wide systems are effectively managed and monitored; (b) anomalies are flagged for prompt investigations to contain any cyber incidents; and (c) user activities in critical systems are logged for audit and investigations. Activity	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	8	
11.1	Cyber Risk Management	A financial institution must ensure that there is an enterprise-wide focus on effective cyber risk management to reflect the collective responsibility of business and technology lines for managing cyber risks.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRp)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
11.2	Cyber Risk Management	A financial institution must develop a CRF which clearly articulates its governance for managing cyber risks, its cyber resilience objectives and its risk tolerance, with due regard to the evolving cyber threat environment. Objectives of the CRF shall include ensuring operational resilience against extreme but plausible cyber-attacks. The framework must be able to support the effective identification, protection, detection, response, and	Functional	Intersects With	Security, Compliance & Resilience Program (SCRp)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	8	
11.2	Cyber Risk Management	A financial institution must develop a CRF which clearly articulates its governance for managing cyber risks, its cyber resilience objectives and its risk tolerance, with due regard to the evolving cyber threat environment. Objectives of the CRF shall include ensuring operational resilience against extreme but plausible cyber-attacks. The framework must be able to support the effective identification, protection, detection, response, and	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	8	
11.2	Cyber Risk Management	A financial institution must develop a CRF which clearly articulates its governance for managing cyber risks, its cyber resilience objectives and its risk tolerance, with due regard to the evolving cyber threat environment. Objectives of the CRF shall include ensuring operational resilience against	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	8	
11.2	Cyber Risk Management	A financial institution must develop a CRF which clearly articulates its governance for managing cyber risks, its cyber resilience objectives and its risk tolerance, with due regard to the evolving cyber threat environment. Objectives of the CRF shall include ensuring operational resilience against extreme but plausible cyber-attacks. The framework must be able to support the effective identification, protection, detection, response, and recovery (IPDRR) of systems and data hosted on-premises or by third party service providers from internal and external cyber-attacks.	Functional	Intersects With	Achieving Resilience Requirements	SEA-01.2	Mechanisms exist to achieve resilience requirements in normal and adverse situations.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.2	Cyber Risk Management	A financial institution must develop a CRF which clearly articulates its governance for managing cyber risks, its cyber resilience objectives and its risk tolerance, with due regard to the evolving cyber threat environment. Objectives of the CRF shall include ensuring operational resilience against extreme but plausible cyber-attacks. The framework must be able to support the effective identification, protection, detection, response, and recovery (IPDRR) of systems and data hosted on-premises or by third party service providers from internal and external cyber-attacks.	Functional	Intersects With	Resilience Capabilities	SEA-01.3	Mechanisms exist to ensure security, compliance and resilience are designed and implemented to provide resistance to: (1) Unintentional errors (by users or software); and (2) Intentional attack or circumvention.	8	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Coordination with Related Plans	IRO-06.1	Mechanisms exist to coordinate incident response testing with organizational elements responsible for related plans.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	
11.3	Cyber Risk Management	The CRF must consist of, at a minimum, the following elements: (a) development of an institutional understanding of the overall cyber risk context in relation to the financial institution's business and operations, its exposure to cyber risks and current cybersecurity posture; (b) identification, classification and prioritisation of critical systems, information, assets and interconnectivity (with internal and external parties) to obtain a complete and accurate view of the financial institution's information assets, critical systems, interdependencies and cyber risk profile; (c) identification of cybersecurity threats, vulnerabilities and countermeasures to secure digital services delivery against cyber-attacks and contain reputational damage that can undermine confidence in the financial institution; (d) enhancing layers of cyber defence with reference to the latest international standards and sound practices such as zero-trust principles, defense-in-depth through micro-segmentation and security by design, to protect its data, infrastructure and assets against evolving cyber threats; (e) timely detection of cybersecurity incidents through continuous surveillance and monitoring; (f) detailed incident handling policies and procedures and a crisis response management playbook to support the swift recovery from cyber incidents and contain any damage resulting from a cybersecurity breach; (g) policies and procedures for timely and secure information sharing and collaboration with other financial institutions and participants in financial market infrastructure to strengthen cyber resilience and fraud prevention; (h) implement a centralised automated tracking system to manage its technology asset inventory; and (i) establish a cyber risk management function to analyse actual and potential cyber threats, providing risk assessments and timely escalation of high-risk cyber threats to senior management and the board. This function shall be performed by an in-house dedicated team or by leveraging on the parent or group.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	
11.4	Cyber Risk Management	A financial institution that is designated as a National Critical Information Infrastructure (NCII) entity pursuant to the Cyber Security Act 2024 must ensure compliance to the requirements and guidelines applicable to NCII, including any additional directives and standards issued by the National Cyber Security Agency (NACSA).	Functional	No Relationship	N/A	N/A	N/A	0	
11.5	Cyber Risk Management	A financial institution must adopt robust control measures as outlined in Appendix 5 to enhance its resilience to cyber-attacks.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRfP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.6	Cyber Risk Management	A financial institution must conduct a realistic "Red Team" simulation attack on its infrastructure at least once every three years to proactively identify and manage potential vulnerabilities.	Functional	Equal	Red Team Exercises	VPM-10	Mechanisms exist to utilize "red team" exercises to simulate attempts by adversaries to compromise Technology Assets, Applications and/or Services (TAAS) in accordance with organization-defined rules of engagement.	10	
11.7	Cyber Risk Management	A financial institution may implement crowdsourced security testing programs as a complement to existing security assessments, in order to thoroughly test the security of their IT environment. The financial institution must engage reputable and credible service providers to facilitate the program.	Functional	Intersects With	Vulnerability Disclosure Program (VDP)	THR-06	Mechanisms exist to establish a Vulnerability Disclosure Program (VDP) to assist with the secure development and maintenance of Technology Assets, Applications and/or Services (TAAS) that receives unsolicited input from the public about vulnerabilities in organizational TAAS.	5	
11.8	Cybersecurity Operations	A financial institution must establish clear responsibilities for cybersecurity operations which shall include implementing appropriate mitigating measures in the financial institution's conduct of business that correspond to the following phases of the cyber-attack lifecycle: (a)	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets.	5	
11.8	Cybersecurity Operations	A financial institution must establish clear responsibilities for cybersecurity operations which shall include implementing appropriate mitigating measures in the financial institution's conduct of business that correspond to the following phases of the cyber-attack lifecycle: (a)	Functional	Intersects With	Authoritative Chain of Command	GOV-04.2	Mechanisms exist to establish an authoritative chain of command with clear lines of communication to remove ambiguity from individuals and teams related to managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and equipped with the necessary tools and technologies for proactive	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and equipped with the necessary tools and technologies for proactive	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and equipped with the necessary tools and technologies for proactive monitoring of its technology security posture; (b) ensuring the scope of monitoring must cover all critical systems including the supporting infrastructure; and (c) conducting regular review of its security posture via the conduct of a vulnerability assessment and penetration testing in line with Appendix 5.	Functional	Intersects With	Security Operations Center (SOC)	OPS-04	Mechanisms exist to establish and maintain a Security Operations Center (SOC) that facilitates a 24x7 response capability.	5	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and equipped with the necessary tools and technologies for proactive monitoring of its technology security posture; (b) ensuring the scope of monitoring must cover all critical systems including the supporting infrastructure; and (c) conducting regular review of its security posture via the conduct of a vulnerability assessment and penetration testing in line with Appendix 5.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	3	
11.9	Cybersecurity Operations	A financial institution must ensure continuous and proactive monitoring and timely detection of anomalous activities in its technology infrastructure to prevent potential compromise of its security controls or weakening of its security posture. This shall include: (a) establishing a Security Operations Center (SOC) supported by competent resources and equipped with the necessary tools and technologies for proactive monitoring of its technology security posture; (b) ensuring the scope of monitoring must cover all critical systems including the supporting infrastructure; and (c) conducting regular review of its security posture via the conduct of a vulnerability assessment and penetration testing in line with Appendix 5.	Functional	Intersects With	Penetration Testing	VPM-07	Mechanisms exist to conduct penetration testing on Technology Assets, Applications and/or Services (TAAS).	3	
11.10	Cybersecurity Operations	A financial institution must establish a process to collect, analyse and evaluate cyber threat information in relation to its environment ("cyber threat intelligence") to promptly detect cyber threats, including data breach incidents and spread of misleading information in relation to the financial institution over the Internet.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	5	
11.10	Cybersecurity Operations	A financial institution must establish a process to collect, analyse and evaluate cyber threat information in relation to its environment ("cyber threat intelligence") to promptly detect cyber threats, including data breach incidents and spread of misleading information in relation to the financial institution over the Internet.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.10	Cybersecurity Operations	A financial institution must establish a process to collect, analyse and evaluate cyber threat information in relation to its environment ("cyber threat intelligence") to promptly detect cyber threats, including data breach incidents and spread of misleading information in relation to the financial institution over the Internet.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
11.11	Cybersecurity Operations	A financial institution must establish appropriate response to investigate and respond to flagged anomalous activities based on their level of complexity.	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
11.12	Cyber Response and Recovery	A financial institution must establish comprehensive cyber crisis management policies and procedures that incorporate cyber-attack scenarios and responses in the organisation's overall crisis management plan, escalation processes, business continuity and disaster recovery planning. This includes developing a clear communication plan for A financial institution must establish comprehensive cyber crisis management policies and procedures that incorporate cyber-attack scenarios and responses in the organisation's overall crisis management plan, escalation processes, business continuity and disaster recovery planning. This includes developing a clear communication plan for	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	
11.12	Cyber Response and Recovery	A financial institution must establish comprehensive cyber crisis management policies and procedures that incorporate cyber-attack scenarios and responses in the organisation's overall crisis management plan, escalation processes, business continuity and disaster recovery planning. This includes developing a clear communication plan for	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	8	
11.13	Cyber Response and Recovery	A financial institution must establish and implement a comprehensive Cyber Incident Response Plan (CIRP). The CIRP must address the following: (a) PreparednessEstablish a clear governance process, reporting structure and roles and responsibilities of the Cyber Emergency Response Team (CERT) as well as invocation and escalation procedures in the event of an incident; (b) Detection and analysisEnsure effective and expedient processes for identifying points of compromise, assessing the extent of	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	8	
11.13	Cyber Response and Recovery	A financial institution must establish and implement a comprehensive Cyber Incident Response Plan (CIRP). The CIRP must address the following: (a) PreparednessEstablish a clear governance process, reporting structure and roles and responsibilities of the Cyber Emergency Response Team (CERT) as well as invocation and escalation procedures in the event of an incident; (b) Detection and analysisEnsure effective and expedient processes for identifying points of compromise, assessing the extent of	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	8	
11.14	Cyber Response and Recovery	A financial institution must ensure that relevant CERT members are conversant with the incident response plan and handling procedures and remain contactable at all times.	Functional	Subset Of	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	10	
11.15	Cyber Response and Recovery	A financial institution shall establish a secure and reliable out-of-band communication infrastructure for both internal and external stakeholders to ensure continued coordination and communication if the primary communication infrastructure is compromised or rendered unavailable during a crisis.	Functional	Intersects With	Recovery Operations Communications	BCD-01.6	Mechanisms exist to communicate the status of recovery activities and progress in restoring operational capabilities to designated internal and external stakeholders.	5	
11.15	Cyber Response and Recovery	A financial institution shall establish a secure and reliable out-of-band communication infrastructure for both internal and external stakeholders to ensure continued coordination and communication if the primary communication infrastructure is compromised or rendered unavailable during a crisis.	Functional	Intersects With	Alternate Communications Channels	BCD-10.4	Mechanisms exist to maintain command and control capabilities via alternate communications channels and designating alternative decision makers if primary decision makers are unavailable.	5	
11.16	Cyber Response and Recovery	A financial institution must conduct an annual cyber drill exercise to test the effectiveness of its CIRP including the out-of-band communication methods, based on various current and emerging threat scenarios (e.g. social engineering), with the involvement of key stakeholders including members of the board, senior management and relevant third party service providers. The result of the annual cyber drill exercise must be reported to the board in a timely manner. The test scenarios must include scenarios designed to test: (a) the effectiveness of escalation, internal and external communication and decision-making processes that correspond to different impact levels of a cyber incident; and (b) the readiness and effectiveness of CERT and relevant third party service providers in supporting the recovery process.	Functional	Subset Of	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	10	
11.17	Cyber Response and Recovery	A financial institution shall review its loss provision arrangements to ensure its adequacy to cover cyber incidents based on its scenario analysis of extreme adverse events. Where cyber insurance is adopted to mitigate impact of cyber incidents, the financial institution shall: (a) ensure that the	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
11.17	Cyber Response and Recovery	A financial institution shall review its loss provision arrangements to ensure its adequacy to cover cyber incidents based on its scenario analysis of extreme adverse events. Where cyber insurance is adopted to mitigate impact of cyber incidents, the financial institution shall: (a) ensure that the scope of the insurance policy adequately covers the information security	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service	5	
11.18	Cyber Reporting and Threat Information Sharing	A financial institution is required to notify the Bank of cyber incidents in adherence to the Bank's policy documents on Operational Risk ReportinPart C, Business Continuity Management – Part C, Merchant Acquiring Serviceparagraphs 19.25 to 19.26 and any other relevant policy documents specified by the Bank.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
11.19	Cyber Reporting and Threat Information Sharing	Subject to the applicable data protection laws, a financial institution must share cyber threat intelligence information with the industry on a timely basis via the relevant sharing platforms developed by the Bank, the industry, or law enforcement agencies. In addition, the financial institution must allocate resources to participate in any industry-wide initiatives aimed at improving collective threat intelligence capabilities.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.20	Cyber Reporting and Threat Information Sharing	A financial institution shall collaborate and cooperate closely with relevant stakeholders and authorities in combating cyber threats.	Functional	No Relationship	N/A	N/A	N/A	0	
12.1	Security of Digital Services	Securing digital services is an integral part of financial institution's risk management. A financial institution must expand its CRF to implement robust technology security controls in providing digital services which assure the following: (a) adopt and regularly assess the minimum-security controls for respective delivery channels to ensure confidentiality and integrity of customer and counterparty information and transactions. Refer to Appendices 2, 3, 4 and 11; (b) proper authentication of users or devices and authorization of transactions to mitigate impersonation and fraud risk. Refer the minimum-security controls in Appendix 3; and (c) strong physical control and logical control measures.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	
12.1	Security of Digital Services	Securing digital services is an integral part of financial institution's risk management. A financial institution must expand its CRF to implement robust technology security controls in providing digital services which assure the following: (a) adopt and regularly assess the minimum-security controls for respective delivery channels to ensure confidentiality and integrity of customer and counterparty information and transactions. Refer to Appendices 2, 3, 4 and 11; (b) proper authentication of users or devices and authorization of transactions to mitigate impersonation and fraud risk. Refer the minimum-security controls in Appendix 3; and (c) strong physical control and logical control measures.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality;	8	
12.1	Security of Digital Services	Securing digital services is an integral part of financial institution's risk management. A financial institution must expand its CRF to implement robust technology security controls in providing digital services which assure the following: (a) adopt and regularly assess the minimum-security controls for respective delivery channels to ensure confidentiality and integrity of customer and counterparty information and transactions. Refer to Appendices 2, 3, 4 and 11; (b) proper authentication of users or devices and authorization of transactions to mitigate impersonation and fraud risk. Refer the minimum-security controls in Appendix 3; and (c) strong physical control and logical control measures.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
12.1	Security of Digital Services	Securing digital services is an integral part of financial institution's risk management. A financial institution must expand its CRF to implement robust technology security controls in providing digital services which assure the following: (a) adopt and regularly assess the minimum-security controls for respective delivery channels to ensure confidentiality and integrity of customer and counterparty information and transactions. Refer to Appendices 2, 3, 4 and 11; (b) proper authentication of users or devices and authorization of transactions to mitigate impersonation and fraud risk. Refer the minimum-security controls in Appendix 3; and (c) strong physical control and logical control measures.	Functional	Intersects With	Products With Digital Elements	TDA-02.12	Mechanisms exist to categorize applicable security and resiliency requirements for products and/or services with digital elements.	5	
12.2	Security of Digital Services	In the event that a financial institution has not yet implemented the digital services security controls specified under paragraph 12.1 to 12.9, the financial institution must- (a) be ready to provide documented explanation of how alternatives measures or mitigations achieve equivalent or superior effectiveness; and (b) assume the liability of any fraud that occurs due to the gaps arising from the absence of the specified control.	Functional	No Relationship	N/A	N/A	N/A	0	
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach.	Functional	Intersects With	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	8	
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach.	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	8	
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	8	
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach involving digital services; (e) formalise operational arrangement to enable swift coordinated response and rapid upgrade of countermeasures to defend against advanced fraud tactics if a financial institution relies on multiple business functions; (f) conduct regular review by senior management to ensure the effectiveness of digital fraud management and define threshold for escalation of countermeasures considering the actual impact to victims of digital fraud and emerging fraud environment; and (g) apprise the board on the outcome of management reviews to preserve public confidence in the security of digital services and mitigate reputation risk to the industry.	Functional	Intersects With	Layered Network Defenses	NET-02	Mechanisms exist to implement security functions as a layered structure that minimizes interactions between layers of the design and avoids any dependence by lower layers on the functionality or correctness of higher layers.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.3	Digital Fraud Management and Customer Awareness	A financial institution must enhance its CRF as follows: (a) expand the scope of identification of cybersecurity threats and countermeasures to include customers' mobile devices and access points; (b) adopt layered (defense-in-depth) security controls to protect the digital service application deployed to customers' mobile devices and the relevant banking data contained in it; (c) perform continuous surveillance and monitoring to detect any exploitation of the digital service application deployed to customers' mobile devices and ensure the swift upgrade of security controls to mitigate new vulnerabilities; (d) establish clearly defined and effective incident handling procedures to assist customers to contain the potential damage resulting from a cybersecurity breach involving digital services; (e) formalise operational arrangement to enable swift coordinated response and rapid upgrade of countermeasures to defend against advanced fraud tactics if a financial institution relies on multiple business functions; (f) conduct regular review by senior management to ensure the effectiveness of digital fraud management and define threshold for escalation of countermeasures considering the actual impact to victims of digital fraud and emerging fraud environment; and (g) apprise the board on the outcome of management reviews to preserve public confidence in the security of digital services and mitigate reputation risk to the industry.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
12.4	Digital Fraud Management and Customer Awareness	A financial institution must ensure that its fraud detection capabilities and rules are updated in a timely manner upon detection of new fraud modus operandi in order to prevent fraudulent transactions or account takeover using stolen customer credentials. This must be supported by appropriate risk analytics to improve the accuracy of fraud detection, that includes continuous upgrade of fraud detection capabilities as specified in Appendix 11 on Fraud Detection Standards.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
12.4	Digital Fraud Management and Customer Awareness	A financial institution must ensure that its fraud detection capabilities and rules are updated in a timely manner upon detection of new fraud modus operandi in order to prevent fraudulent transactions or account takeover using stolen customer credentials. This must be supported by appropriate risk analytics to improve the accuracy of fraud detection, that includes continuous upgrade of fraud detection capabilities as specified in Appendix 11 on Fraud Detection Standards.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	
12.5	Digital Fraud Management and Customer Awareness	A financial institution must mitigate any attendant risk arising from its delivery of digital services. This shall include- (a) adopt secure communication channel to mitigate risk of phishing. Compensating controls shall be adopted when using communication channel prone to phishing exploits; (b) all customers must be properly informed in advance of new controls to ease adoption and minimise inconvenience; and (c) practical ways for customers to verify the authenticity of calls made by the financial institution or its appointed outsourced service providers.	Functional	Intersects With	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	3	
12.5	Digital Fraud Management and Customer Awareness	A financial institution must mitigate any attendant risk arising from its delivery of digital services. This shall include- (a) adopt secure communication channel to mitigate risk of phishing. Compensating controls shall be adopted when using communication channel prone to phishing exploits; (b) all customers must be properly informed in advance of new controls to ease adoption and minimise inconvenience; and (c) practical ways for customers to verify the authenticity of calls made by the financial institution or its appointed outsourced service providers.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	3	
12.5	Digital Fraud Management and Customer Awareness	A financial institution must mitigate any attendant risk arising from its delivery of digital services. This shall include- (a) adopt secure communication channel to mitigate risk of phishing. Compensating controls shall be adopted when using communication channel prone to phishing exploits; (b) all customers must be properly informed in advance of new controls to ease adoption and minimise inconvenience; and (c) practical ways for customers to verify the authenticity of calls made by the	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and	3	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
12.5	Digital Fraud Management and Customer Awareness	A financial institution must mitigate any attendant risk arising from its delivery of digital services. This shall include: (a) adopt secure communication channel to mitigate risk of phishing. Compensating controls shall be adopted when using communication channel prone to phishing exploits; (b) all customers must be properly informed in advance of new controls to ease adoption and minimise inconvenience; and (c) practical ways for customers to verify the authenticity of calls made by the	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	3	
12.6	Digital Fraud Management and Customer Awareness	A financial institution shall empower customers to mitigate digital fraud risks where it is reasonably practical. This shall include offering customer mechanisms to manage activation and de-activation of payment card for card-not-present and overseas transactions. This shall not absolve the financial institution from its liabilities, responsibilities and duty of care to ensure the security of its digital services.	Functional	No Relationship	N/A	N/A	N/A	0	
12.7	Digital Fraud Management and Customer Awareness	A financial institution must maintain continuous efforts to review and enhance the effectiveness of its awareness programmes, ensuring customers understand the risks of digital services fraud. This shall include: (a) continuous and timely updates of practical information on how to identify potential fraud, including specific information about new or common modus operandi; (b) clear explanation about new and existing security measures, such as how to verify genuine e-banking websites and mobile applications; (c) real-time alerts of possible risks when security measures are absent or have not yet been implemented; and (d) measures	Functional	No Relationship	N/A	N/A	N/A	0	
12.8	Digital Fraud Management and Customer Awareness	A financial institution must provide convenient means for customers to report, suspend and re-activate their account swiftly in the event of a suspected fraud, where applicable. This shall require the financial institution to: (a) offer a secure self-service "kill switch" solution; (b) ensure that its contact centre is adequately resourced and operating effectively to provide prompt and adequate assistance to customers in distress; and (c) restore customer access to digital services within a reasonable timeframe upon validation.	Functional	Intersects With	Grievances	CPL-07	Mechanisms exist to govern the intake and analysis of grievances related to the organization's cybersecurity and/or data protection practices.	5	
12.9	Digital Fraud Management and Customer Awareness	In addition to effective incident handling procedures, a financial institution must adopt additional measures to mitigate risk to customers arising from any incident involving potential fraud or compromise of customer data. This shall include: (a) heighten monitoring of affected customer accounts; (b) notify affected customers and provide them with the necessary information to apply mitigating measures and reduce the risk of fraud; and (c) revoke and re-issue affected user credentials or designated payment instruments, where there is a potential risk of exploitation due to compromised data or other fraudulent activity.	Functional	No Relationship	N/A	N/A	N/A	0	
13.1	Audit Function	A financial institution must ensure that the scope, frequency, and intensity of technology audits are commensurate with the complexity, sophistication and criticality of technology systems and applications.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
13.2	Audit Function	A financial institution must establish annual review on its technology audit plan that provides appropriate frequency and coverage of critical technology services, third party service providers, material external system interfaces, delayed or prematurely terminated critical technology projects and post-implementation review of new or material enhancements of technology services.	Functional	Intersects With	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	5	
13.3	Audit Function	A financial institution must ensure the internal audit function must have dedicated technology audit resources with specialised competencies and professionally certified. The technology audit resources shall be adequately conversant with the developing sophistication of the financial institution's technology systems, delivery channels and have sound knowledge in the areas audited.	Functional	Intersects With	Internal Audit Function	CPL-02.1	Mechanisms exist to implement an internal audit function that is capable of providing senior organization management with insights into the appropriateness of the organization's technology and information governance processes.	5	
13.4	Audit Function	The technology audit resources may be enlisted to provide advice on compliance and adequacy of control processes during the planning and development phases of new major products, systems, adoption of third party service providers or technology operations. In such cases, the technology auditors participating in this capacity are expected to carefully consider whether such an advisory or consulting role can materially impair their independence or objectivity in performing post-implementation reviews of the products, systems and operations concerned.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
14.1	External Party Assurance	A financial institution shall appoint a technically competent external service provider to carry out a production data centre resilience and risk assessment (DCRA). The assessment must consider all major risks and determine the current level of resilience of the production data centre. A	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
14.2	External Party Assurance	A financial institution shall appoint a technically competent external service provider to carry out regular network resilience and risk assessments (NRA) and set proportionate controls aligned with its risk appetite. The assessment must be conducted at least once in three years or whenever there is a material change in the network design, whichever is earlier. The assessment must consider all major risks and determine the	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
15.1	Security Awareness and Education	A financial institution must provide adequate and regular technology and cybersecurity awareness education for all staff in undertaking their respective roles and measure the effectiveness of its education and awareness programs. This cybersecurity awareness education must be conducted at least annually and must reflect the evolving cyber threat landscape and emerging risks. Where appropriate, the financial institution	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	8	
15.2	Security Awareness and Education	A financial institution must provide adequate and continuous training for staff involved in technology operations, cybersecurity and risk management in order to ensure that the staff are competent and suitably certified to effectively perform their roles and responsibilities.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
15.2	Security Awareness and Education	A financial institution must provide adequate and continuous training for staff involved in technology operations, cybersecurity and risk management in order to ensure that the staff are competent and suitably certified to effectively perform their roles and responsibilities.	Functional	Intersects With	Continuing Professional Education (CPE) - Security, Compliance & Resilience Personnel	SAT-03.7	Mechanisms exist to ensure security, compliance and resilience personnel receive Continuing Professional Education (CPE) training to maintain currency and proficiency with industry-recognized secure practices that are pertinent to their assigned roles and responsibilities.	3	
15.3	Security Awareness and Education	A financial institution must provide its board members with regular training and information on technology developments to enable the board to effectively discharge its oversight role.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	5	
16.1	Introduction or Enhancement to Digital Services	A financial institution must notify the Bank in accordance with the requirements in paragraphs 16.2 to 16.7 prior to introducing new digital services or enhancement to existing digital services.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
16.2	Introduction or Enhancement to Digital Services	A financial institution offering digital services for the first time must undertake measures specified under paragraph 16.4 and submit the following information in the notification to the Bank: (a) assessment on the risks identified and strategies to manage such risks. This includes specific accountabilities, policies and controls to address risks; (b) security arrangements and controls; (c) significant terms and conditions; (d) client	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	
16.2	Introduction or Enhancement to Digital Services	A financial institution offering digital services for the first time must undertake measures specified under paragraph 16.4 and submit the following information in the notification to the Bank: (a) assessment on the risks identified and strategies to manage such risks. This includes specific accountabilities, policies and controls to address risks; (b) security arrangements and controls; (c) significant terms and conditions; (d) client	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is	5	
16.3	Introduction or Enhancement to Digital Services	For any enhancements to existing digital services which meet the criteria in Appendix 6, a financial institution shall be subject to a simplified notification requirement and submit the following information in the notification to the Bank: (a) description of the enhancements to the existing technologies; and (b) risk assessment of the proposed enhancements, including the impact and measures to mitigate identified	Functional	No Relationship	N/A	N/A	N/A	0	
16.4	Introduction or Enhancement to Digital Services	For any enhancements to existing digital services which are not subject to the simplified notification requirement under paragraph 16.3, a financial institution is required to undertake the following measures prior to notifying	Functional	Intersects With	Assessments	IAQ-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to	5	
16.5	Introduction or Enhancement to Digital Services	A financial institution must ensure that the independent external party providing the assurance is competent and has a good track record. The assurance shall address the matters covered in, and comply with, Part C and D of Appendix 7.	Functional	Intersects With	Assessment Team Subject Matter Expertise	CPL-01.6	Mechanisms exist to ensure individuals performing audits and/or assessments have reasonable: (1) Professional qualifications to perform the audit and/or assessment; and (2) Subject matter expertise to perform review, interview and test activities for in-scope People, Processes, Technologies, Data and/or Facilities (PPTDF).	5	
16.6	Introduction or Enhancement to Digital Services	A financial institution shall provide relevant documents for the Bank's review when required by the Bank.	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
16.7	Introduction or Enhancement to Digital Services	A financial institution may offer digital services or implement any enhancement to the digital services immediately upon submission of the notification under paragraph 16.1 and compliance with the requirements in paragraphs 16.2 to 16.6.	Functional	No Relationship	N/A	N/A	N/A	0	
17.1	Consultation and Notification related to Cloud Services and Emerging Technology	A financial institution is required to consult the Bank prior to the first-time adoption of a public cloud or emerging technology for critical systems. During the consultation, the financial institution must demonstrate that specific risks associated with the use of these technologies have been adequately considered and addressed to the satisfaction of the Bank. The financial institution shall undertake the following prior to consulting the Bank: (a) conduct a comprehensive risk assessment of the proposed cloud adoption or emerging technology, including the possible impact and measures to address and mitigate the identified risks. For public cloud, the assessment must follow the risk outlined in paragraph 10.50 and Appendix 10. For emerging technology, it must follow the guideline in Appendix 9. The financial institution shall also adopt the format of the Risk Assessment Report as per Part A of Appendix 7; (b) provide a confirmation by the CISO, senior management officer, or the chairman of the board or designated	Functional	No Relationship	N/A	N/A	N/A	0	
17.2	Consultation and Notification related to Cloud Services and Emerging Technology	A financial institution shall notify the Bank on any subsequent adoption of a public cloud or emerging technology for critical system, by submitting the notification together with the necessary updates to all the information required under paragraph 17.1, subject to the financial institution having complied with the following requirements: (a) has consulted the Bank prior to adopting a public cloud or emerging technology for critical systems for the first time in accordance with paragraph 17.1, with no concerns raised	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
17.3	Consultation and Notification related to Cloud Services and Emerging Technology	For the avoidance of doubt, notification to the Bank under paragraph 17.2 is not required for any enhancement to existing cloud adoption and emerging technology adoption that does not materially alter the prior assessments and representations made by a financial institution to the	Functional	No Relationship	N/A	N/A	N/A	0	
17.4	Consultation and Notification related to Cloud Services and Emerging Technology	The Bank may at its discretion direct a financial institution to consult the Bank under paragraph 17.1, notify the Bank under paragraph 17.2 or observe any of the guidance in Appendix 10 or Appendix 9 and to explain any deviations from the guidance in Appendix 10 or Appendix 9, including	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
17.5	Consultation and Notification related to Cloud Services and Emerging Technology	A financial institution must ensure the roadmap for adoption of cloud services or emerging technology (for critical systems and non-critical systems) is included in the annual outsourcing plan submitted to the Bank in adherence with the requirements in the policy document on Outsourcing or IT Profile reporting. The risk assessment as outlined in paragraph 10.50 for cloud services or Appendix 9 for emerging technology must also be documented and made available for the Bank's review as and when requested by the Bank.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
18.1	Assessment and Gap Analysis	A financial institution must perform a gap analysis of existing practices in managing technology risk against the requirements in this policy document and highlight key implementation gaps. The financial institution must develop an action plan with a clear timeline and key milestones to address the gaps identified. The gap analysis and action plan must be submitted to the Bank no later than 90 days after the issuance date of this policy document. Financial institutions that have previously made a submission in accordance with the equivalent provision in the previous version of this policy document are required to maintain continuous compliance by identifying any new gaps against the enhanced or revised requirements in the latest version of this policy document and taking the necessary steps to address such gaps. The updated annual assessment of its level of compliance must be made available to the Bank upon request.	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
18.2	Assessment and Gap Analysis	The self-assessment, gap analysis and action plan in paragraph 18.1 must be submitted to Jabatan Penyeliaan Konglomerat Kewangan, Jabatan Penyeliaan Perbankan, Jabatan Penyeliaan Insurans dan Takaful or Jabatan Pemantauan Perkhidmatan Pembayaran, as the case may be.	Functional	Intersects With	Declaration of Conformity	CPL-01.5	Mechanisms exist to generate a declaration of conformity for each conformity assessment, where the document: (1) Is concise; (2) Unambiguously reflects the current status; (3) Is physically or electronically signed; and	5	